

국가유산청 정보보안 세부지침

제정	1999. 11.4.	문화재청	행정지침	제 21호
전문개정	2004. 11.5.	문화재청	행정지침	제 22호
폐지	2009. 8.28.	문화재청	행정지침	제 49호
재발령	2009. 8.28.	문화재청	훈령	제159호
일부개정	2009. 12.14.	문화재청	훈령	제189호
일부개정	2010. 3.16.	문화재청	훈령	제204호
일부개정	2011. 5.16.	문화재청	훈령	제231호
일부개정	2015. 8.20.	문화재청	훈령	제364호
전부개정	2019. 11.1.	문화재청	훈령	제508호
일부개정	2020. 6.1.	문화재청	훈령	제536호
전부개정	2021. 8.25.	문화재청	훈령	제576호
일부개정	2022. 1.19.	문화재청	훈령	제590호
일부개정	2022. 5.2.	문화재청	훈령	제602호
타법개정	2024. 5. 17.	국가유산청	훈령	제2호

제 1 장 총 칙

제1조(목적) 이 지침은 「국가유산청 보안업무규정 시행세칙」 및 국가정보원 「국가 정보보안 기본지침」에 따라 국가유산청 정보보안 활동에 필요한 세부 절차를 정함을 목적으로 한다.

제2조(적용범위) ① 이 지침은 국가유산청 (소속기관과 산하기관을 포함한다, 이하 "각 기관"이라 한다)에 대하여 적용한다.

② 정보보안업무에 관하여는 다른 법령에 특별한 규정이 있는 경우를 제외하

고는 이 지침이 정하는 바에 따른다.

제3조(용어의 정의) 이 지침에서 사용하는 용어의 정의는 다음과 같다.

1. "정보보안"이라 함은 국가유산청의 기능 유지를 주 목적으로 정보시스템 및 정보통신망을 통해 수집·생산·가공·저장·검색·송수신되는 정보의 유출·위변조·훼손 등을 방지하기 위하여 관리적·물리적·기술적 수단을 강구하는 일체의 행위를 말한다.
2. "디지털정보담당관"이라 함은 정보보안업무를 총괄하기 위하여 국가유산청장이 임명한 사람을 말한다.
3. "공무원등"이라 함은 각 기관에 근무 중인 다음 각 목의 어느 하나에 해당하는 사람을 말한다.
 - 가. 「국가공무원법」 제2조에 따른 국가공무원
 - 나. 「지방공무원법」 제2조에 따른 지방공무원
 - 다. 공공기관 임직원
 - 라. 공무원직 근로자 및 기간제 근로자
4. "정보통신망"이라 함은 「사이버안보 업무규정」 제2조제1호에 따른 정보통신망을 말한다.
5. "업무전산망"(이하 "업무망" 또는 "내부망"이라 한다)이라 함은 기관의 네트워크 중에서 인터넷망과 분리하여 구축한 업무 전용(專用) 정보통신망을 말한다.
6. "기관 인터넷망"이라 함은 업무 활용 또는 공개서버 운용을 주(主) 목적으로 인터넷과 연동하여 구축한 정보통신망을 말한다.
7. "상용 인터넷망"이라 함은 기관 인터넷망과 별개로 소속 공무원등이나 민원인 등의 보편적인 편의성을 위하여 인터넷에 연동하여 구축한 정보통신망을 말한다.
8. "정보통신실"이라 함은 서버·스위치·라우터 등 전산 및 통신장비 등이 설치·운용되는 장소를 말한다.
9. "단말기"라 함은 정보통신망을 통하여 주전산기에 자료를 입력하거나 주전산기에 저장된 자료를 조회 또는 출력하기 위하여 사용되는 장치를 말한다.

단말기 기능과 워드프로세스 기능 등을 동시에 수행하거나, LAN(근거리통신망)에 연결되어 있는 개인용 컴퓨터는 단말기로 본다.

10. "휴대용 저장매체"라 함은 외장형 하드디스크(HDD), USB메모리, CD, DVD 등 자료를 저장할 수 있는 일체의 것으로 PC 등의 정보통신시스템과 분리할 수 있는 기억장치를 말한다.

11. "업무자료"라 함은 다음 각 목의 어느 하나에 해당하는 것을 말한다.

가. 「전자정부법」 제2조제6호에 따른 행정정보 및 같은 법 제2조제7호에 따른 전자문서

나. 「공공기록물 관리에 관한 법률 시행령」 제2조제2호에 따른 전자기록물다. 기타 다른 법령에 의하여 직무상 작성·취득하였거나 보유·관리하는 자료로서 전자적으로 처리되어 부호·문자·음성·음향·영상 등으로 표현된 것

12. "비밀"이라 함은 업무자료 중에서 「보안업무규정」 제4조에 따라 분류된 비밀을 말한다.

13. "대외비"라 함은 업무자료 중에서 「보안업무규정 시행규칙」 제16조제3항에 따라 분류된 대외비를 말한다.

14. "비공개 업무자료"라 함은 비밀 및 대외비를 제외한 업무자료 중에서 다음 각 목의 어느 하나에 해당하는 자료 또는 정보를 말한다.

가. 「공공기관의 정보공개에 관한 법률」 제9조제1항에 따른 비공개 대상 정보

나. 국회 소속 공무원(「국회의원수당 등에 관한 법률」 제9조에 따른 보좌직원을 포함한다)의 직무상 요구에 따라 작성 또는 취득한 자료

다. 가목에 따른 비공개 대상 정보의 주요 내용이 기술된 문장 또는 문구

15. "정보보호시스템"이라 함은 「지능정보화 기본법」 제2조제15호에 따른 정보보호시스템을 말한다.

16. "안전성 검증필 제품"이라 함은 국가정보원장이 국가용 보안요구사항 만족여부 등 안전성을 확인하여 제21조에 따른 안전성 검증필 제품 목록에 등재한 정보통신제품을 말한다.

17. "보안적합성 검증"이라 함은 제20조제1항제3호의 보안기능이 있는 정보통신제품에 대하여 실제 적용·운용 이전에 시험 등의 방법으로 안전성을

검증하는 활동을 말한다.

18. "암호자재"라 함은 비밀의 보호 및 정보통신 보안을 위하여 사용되는 암호기술이 적용된 장치나 수단으로서 I 급, II 급 및 III 급 비밀 소통용 암호자재로 구분되는 장치나 수단을 말한다.
19. "암호장비"라 함은 암호자재 중에서 국가정보원장이 승인하여 개발·제작·보급되는 암호자재를 말한다.
20. "암호알고리즘"라 함은 정보의 유출, 위·변조, 훼손 등을 방지하기 위하여 기밀성·무결성·인증·부인방지 등의 기능을 제공하는 수학적 논리를 말한다.
21. "사이버공격"이라 함은 「사이버안보 업무규정」 제2조제2호에 따른 행위를 말한다.
22. "보안관제"라 함은 사이버공격 정보를 실시간으로 탐지 및 분석, 대응하는 일련의 활동을 말한다.
23. "보안관제센터" 또는 "사이버안전센터" 라 함은 일정한 수준의 시설 및 장비와 이를 운영하기 위한 전문인력을 갖추고 보안관제업무를 수행하는 조직을 말한다.
24. "취약점"이라 함은 사이버공격에 악용되어 관리자가 설정한 접근 권한外 정보를 열람·취득하게 하거나 보안기능을 회피 가능하게 하는 정보통신망·정보시스템의 결함을 말한다.

제 2 장 정보보안 기본활동

제4조(정보보안의 책임) 정보보안에 관한 책임은 각 기관의 장에게 있다.

제5조(정보보안담당관 제도운영) ① 디지털정보담당관을 정보보안담당관으로 임명하고, 본청 및 소속·산하기관에 대한 정보보안 업무를 총괄한다.

② 디지털정보담당관의 임무는 다음과 같다.

1. 정보보안 정책·계획의 수립·시행 및 정보보안 관련 규정·지침 등 제·개정
2. 정보보안 전담조직 관리, 전문인력 및 관련예산 확보
3. 정보화사업 보안성 검토 및 보안적합성 검증 총괄
4. 정보통신망 신·증설시 보안대책 수립
5. 정보통신실, 정보통신망, 정보자료 등의 보안관리
6. 사이버공격 대응훈련, 보안관제, 정보보안사고 대응 및 정보협력 업무 총괄
7. 정보보안교육 총괄 및 '사이버보안진단의 날' 계획 수립·시행
8. 정보보안 업무 지도·감독 및 정보보안감사
9. 기타 정보보안 관련업무

③ 각 기관의 장은 정보보안업무를 효율적으로 수행하기 위하여 부서별 분임 정보보안담당관을 임명·운영하여야 하며 별도로 임명하지 아니할 경우 각 부서의 장을 분임정보보안담당관으로 임명한 것으로 본다.

④ 정보보안담당관은 제2항 각 호에 해당하는 업무를 수행함에 있어 필요한 경우 해당 업무의 일부를 부서 분임정보보안담당관에게 위임할 수 있다.

제6조(정보보안교육) ① 정보보안담당관은 모든 공무원등을 대상으로 정보보안 교육(온라인 교육을 포함한다)을 연1회 이상 실시하여야 한다.

② 제1항에 따라 모든 공무원등은 특별한 사유가 없는 한 연1회 이상 정보보안교육을 이수하여야 한다.

③ 정보보안담당관과 분임정보보안담당관은 정보보안 담당직원의 업무 전문성을 제고하고 정보보안 지식을 함양하기 위하여 전문기관의 교육 이수나 학술회의 참가 등을 장려하여야 한다.

제7조(정보보안감사 등) ① 정보보안담당관은 연 1회 이상 본청 각 부서 및 소속·산하기관에 대하여 정보보안감사를 실시하여야 한다.

② 정보보안담당관은 제1항에 따른 정보보안감사를 실시할 경우 국가정보원장이 배포한 정보보안점검 체크리스트 등을 활용할 수 있다.

③ 각 기관의 장은 정보보안감사 담당자를 다음 각 호의 법규를 준용하여 위대하여야 한다.

1. 「공공감사에 관한 법률」 제18조에 따른 근무성적평정, 임용 등에서 우대
2. 「중앙행정기관 등의 자체감사 역량 강화에 관한 규정」(국무총리훈령) 제7조에 따른 전문역량 강화 및 제9조에 따른 근무성적평정·전보·수당 등에서 우대
3. 「자체감사활동의 지원 및 대행·위탁감사에 관한 규칙」(감사원규칙) 제4조 제4호에 따른 근무여건 개선 및 사기제고

제8조(연도 추진계획 수립) 정보보안담당관은 해당 기관 및 소속·산하기관에 대한 「연도 정보보안업무 추진계획」(「국가사이버안전관리규정」 제9조에 따른 사이버안전대책을 포함한다)을 수립·시행하여야 한다.

제9조(사이버보안진단의 날) ① 정보보안담당관은 매월 세 번째 수요일을 ‘사이버보안진단의 날’로 지정·운영하여야 한다.

② 각 부서 분임정보보안담당관은 정보보안담당관 총괄 하에 ‘사이버보안진단의 날’에 소속 부서의 정보통신망과 정보시스템의 보안취약 여부 확인 등 체계적이고 종합적인 보안진단을 실시하여야 한다.

제 3 장 정보화사업 보안

제1절 사업계획

제10조(정보업무의 위탁) ① 각 기관의 장은 정보업무의 개발 및 운영을 다른 기관에 위탁하고자 하는 경우에는 대상기관의 사회적 신용도 등을 고려하여 선정하여야 한다.

② 각 기관의 장은 위탁계약을 체결하는 경우에는 계약서 등에 정보의 안전성과 정확성을 확보하기 위하여 필요한 작업절차 및 안전관리 기준과 위반 시의

책임 범위에 대한 내용을 명시하여야 한다.

③ 각 기관의 장은 정보업무를 위탁하는 때에는 위탁자의 안전관리 이행 실태를 지도 감독하여야 한다.

제11조(보안책임) ① 각 기관에서 정보통신망 또는 정보시스템을 개발·구축·운용·유지보수하는 사업(「지능정보화 기본법」 제11조제1항에 따른 지능정보화계획에 따른 사업을 포함한다. 이하 "정보화사업"이라 한다)을 수행하는 부서의 장은 해당 정보화사업에 대한 보안관리 책임을 진다.

② 정보화사업을 수행하는 부서의 장은 정보화사업의 수행과 관련한 보안업무에 대하여 관리·감독하여야 한다.

③ 정보보안담당관 및 분임정보보안담당관은 각종 정보화사업과 관련한 보안대책의 적절성을 평가하고 정보화사업 수행 전반에 대하여 보안대책의 이행여부를 점검하여 필요한 경우 정보화사업을 수행하는 부서의 장에게 시정을 요구할 수 있다.

제12조(보안대책 수립) ① 각 기관의 장은 정보통신망 또는 정보시스템을 구축·운용하기 위한 정보화사업 계획을 수립할 경우 다음 각 호의 사항을 포함한 보안대책을 수립·시행하여야 한다.

1. 보안관리체계(조직, 인원 등) 구축 등 관리적 보안대책
2. 설치·운영장소 보안관리 등 물리적 보안대책
3. 정보통신망 또는 정보시스템의 구성요소별 기술적 보안대책
4. 국가정보원장이 개발하거나 안전성을 확인한 암호자재, 검증필 암호모듈 및 정보보호시스템 도입·운영계획
5. 긴급사태 대비 및 재난복구 계획
6. 용역업체 작업장소에 대한 보안대책
7. 기존 운용중인 정보통신망 및 정보시스템에 대한 용역업체 접근통제대책
8. 온라인 개발 또는 온라인 유지보수가 필요하다고 판단할 경우 제24조 또는 제37조제5항에 따른 보안대책
9. 누출금지정보 보안관리 방안

제13조(제안요청서 기재사항) ① 각 기관의 장은 정보화사업을 발주하기 위하여 제안요청서를 작성할 경우 다음 각 호의 사항을 포함하여야 한다.

1. 용역업체 작업장소에 대한 보안요구사항
2. 온라인 개발 또는 온라인 유지보수가 필요하다고 판단할 경우 제24조 또는 제37조제5항에 따른 보안 준수사항
3. 누출금지정보 목록
4. 용역업체가 누출금지정보를 제외한 소프트웨어 산출물을 제3자에게 제공하고자 할 경우 발주자의 승인절차

② 제1항제3호에 따른 누출금지정보 목록을 작성할 경우 다음 각 호의 사항을 포함하여야 한다.

1. 해당 기관의 정보시스템 내·외부 IP주소 현황
2. 정보시스템 구성 현황 및 정보통신망 구성도
3. 개별사용자의 계정·비밀번호 등 정보시스템 접근권한 정보
4. 정보통신망 또는 정보시스템 취약점 분석·평가 결과물
5. 정보화사업 용역 결과물 및 관련 프로그램 소스코드(외부에 유출될 경우 국가안보 및 국익에 피해가 우려되는 중요 용역사업에 해당)
6. 암호자재, 암호가 주 기능인 제품 및 정보보호시스템 도입·운용 현황
7. 정보보호시스템 및 네트워크장비 설정 정보
8. 「공공기관의 정보공개에 관한 법률」 제9조제1항에 따라 비공개 대상 정보로 분류된 해당 기관의 내부분서
9. 「개인정보보호법」 제2조제1호에 따른 개인정보
10. 「보안업무규정」 제4조에 따른 비밀 및 「보안업무규정 시행규칙」 제16조 제3항에 따른 대외비
11. 그 밖에 해당 기관의 장이 공개가 불가하다고 판단한 자료

제2절 보안성 검토

제14조(보안성 검토 시기 및 절차) ① 각 기관의 장은 정보화사업을 수행하고자 할 경우 정보화사업과 관련한 보안대책의 적절성을 평가하기 위하여 사업 계획 단계(사업 공고 전)에서 보안성 검토 절차를 이행하여야 한다.

② 각 기관의 장은 제1항에 따른 보안성 검토를 위하여 제15조제1항 및 제2항에 따른 보안성 검토 기관의 장에게 검토를 의뢰하거나 자체적으로 실시하여야 한다. 각 기관의 장이 제15조제1항 각 호에 해당하는 정보화사업에 대하여 국가정보원장에게 보안성 검토를 의뢰하고자 할 경우 정보보안담당관을 거쳐 의뢰하여야 한다.

제15조(검토 기관) ① 정보보안담당관은 각 기관의 장이 추진하는 다음 각 호에 해당하는 정보화사업에 대하여 국가정보원에 보안성 검토를 의뢰한다. 다만, 국가정보원장이 정보화사업의 규모·중요도 등을 고려하여 정보보안담당관에게 보안성 검토를 위임할 경우 자체적으로 보안성 검토를 실시할 수 있다.

1. 비밀·대외비를 유통·관리하기 위한 정보통신망 또는 정보시스템 구축
2. 국가정보원장이 개발하거나 안전성을 확인한 암호자재를 적용하는 정보통신망 또는 정보시스템 구축
3. 외교·국방 등 국가안보상 중요한 정보통신망 또는 정보시스템 구축
4. 100만명 이상의 개인에 대한 「개인정보보호법」상 민감정보 또는 고유식별 정보를 처리하는 정보시스템 구축
5. 주요정보통신기반시설로 지정이 필요한 정보통신기반시설 구축
6. 「국가 정보보안 기본지침」 제53조의2에 따른 제어시스템 도입
7. 재난관리·국민안전·치안유지·비상사태 대비 등 국가위기 관리와 관련한 정보통신망 또는 정보시스템 구축
8. 국가정보통신망 등 여러 기관이 공동으로 활용하기 위한 정보통신망 또는 정보시스템 구축
9. 행정정보, 국가지리, 환경정보 등 국가 차원의 주요 데이터베이스 구축
10. 정상회의, 국제회의 등 국제행사를 위한 정보통신망 또는 정보시스템 구축
11. 내부망 또는 폐쇄망을 인터넷 또는 다른 정보통신망과 연동하는 사업

12. 내부망과 기관 인터넷망을 분리하는 사업
 13. 통합데이터센터·보안관제센터 구축
 14. 제3조제6호에 따른 기관 인터넷망 등 소속 공무원등이 업무상 목적으로 활용하도록 하기 위한 인터넷망(제43조제1항제1호에 따른 업무용 무선랜 형태를 포함한다) 및 이동통신망(HSDPA, WCDMA, LTE, 5G 등)의 구축
 15. 원격근무시스템 구축
 16. 「전자정부법」 제54조의2 및 「클라우드컴퓨팅 발전 및 이용자 보호에 관한 법률」 제20조에 따라 클라우드컴퓨팅서비스제공자의 클라우드컴퓨팅서비스(이하 "민간 클라우드컴퓨팅서비스"라 한다)를 이용하는 사업
 17. 남북 회담 및 협력사업 등을 위한 북한지역 내 정보통신망 또는 정보시스템 구축
 18. 외국에 개설하는 사무소 운영을 위한 정보통신망 또는 정보시스템 구축
 19. 첨단 정보통신기술을 활용하는 정보화사업으로서 국가정보원장이 해당 기술에 대하여 안전성 확인이 필요하다고 지정하는 사업
- ② 정보보안담당관은 각 기관의 장이 추진하는 다음 각 호에 해당하는 정보화사업에 대하여 보안성 검토를 실시한다. 다만, 산하기관의 장이 추진하는 제10호부터 제14호까지에 해당하는 정보화사업에 대한 보안성 검토는 해당 기관의 장이 실시하도록 위임할 수 있다.
1. 제1항 단서에 따라 국가정보원장으로부터 보안성 검토를 위임받은 사업
 2. 홈페이지 및 웹메일 등 웹기반 정보시스템 구축
 3. 인터넷전화시스템 구축
 4. 다른 기관의 정보통신망 또는 정보시스템과 연동하여 정보의 소통 또는 서비스를 제공하는 정보시스템 구축
 5. 제3조제7호에 따른 상용 인터넷망(제40조제1항제2호 또는 제3호에 따른 무선랜 형태를 포함한다)의 구축
 6. 내부망에 구축하는 공무원등의 인사·복지시스템
 7. 주요정보통신기반시설 취약점 분석·평가, 정보보안컨설팅 등 용역사업
 8. 기존 분리된 내부망·기관 인터넷망간 자료전송시스템 구축 등 후속사업
 9. 대규모 백업·재해복구센터 구축

10. 제42조제1항에 따른 영상회의시스템을 내부망 또는 기관 인터넷망과 분리하여 구축하는 경우
 11. 제75조에 따른 영상정보처리기기를 같은 조 제3항 본문에 따라 인터넷과 분리하여 구축하는 경우
 12. 백업시스템 구축
 13. 대민(對民) 콜센터시스템 구축
 14. 기타 해당 기관의 장이 필요하다고 판단하는 정보통신망 또는 정보시스템 구축
- ③ 정보보안담당관은 제2항에 따라 수행하는 각 기관 정보화사업 보안성 검토 대상 중에서 각 기관이 반복적으로 요청하는 유형에 대하여는 개별적 검토에 갈음하는 기준을 미리 작성·배포할 수 있으며, 각 기관의 장이 이를 준수하여 정보화사업 계획을 수립하였을 경우 제2항에 따른 보안성 검토 절차를 이행한 것으로 본다. 다만, 정보보안담당관은 해당 정보화사업 현황을 파악하여 제19조에 따른 제출시에 포함하여야 하며, 필요시 제18조제2항에 따른 현장 점검을 실시한다.

제16조(검토 생략) ① 각 기관의 장은 다음 각 호에 해당하는 정보화사업에 대하여는 정보보안담당관과 사전 협의를 거쳐 보안성 검토를 생략할 수 있다. 이 경우 각 기관의 장은 관련 매뉴얼·가이드라인 등을 준수하는 등 자체 보안대책을 수립·시행하여야 한다.

1. 제15조제1항 및 제2항 각 호의 정보화사업에 해당하지 아니하는 단순장비·물품 도입
2. 제15조에 따른 보안성 검토를 거쳐 완료한 정보화사업에 대하여 정보통신망 구성을 변경하지 아니하는 범위 내에서 다음 각 목의 사항을 포함한 후속운영·유지보수·컨설팅(단일 회선의 이중화는 본 호를 적용함에 있어 정보통신망 구성의 변경이 아닌 것으로 본다)
 - 가. 서버·스토리지·네트워크장비 등 장비 노후화로 인한 단순 장비 교체
 - 나. 전화기·무전기·CCTV 등 통신·영상기기의 노후화로 인한 단순 장비 교체
 - 다. 기존 운용하던 정보보호시스템을 동일한 보안기능을 보유한 다른 정보보호시스템으로 교체

3. 다년도에 걸쳐 계속되는 사업으로써 사업 착수 당시 보안성 검토를 완료한 후 사업 내용의 변동 없이 계속 추진하는 운영·유지사업
 4. PC·프린터 및 상용 소프트웨어 등 단순 제품 교체
- ② 각 기관의 장은 제1항제2호부터 제4호까지에 해당하는 정보화사업을 수행할 경우 기존 보안성 검토결과를 준수하여야 한다.

제17조(제출 문서) 각 기관의 장은 보안성 검토를 의뢰할 경우 다음 각 호의 사항이 포함된 문서를 제출하여야 한다.

1. 사업계획서(사업목적 및 추진계획을 포함한다)
2. 제안요청서
3. 정보통신망 구성도(필요시 IP주소체계를 추가한다)
4. 자체 보안대책

제18조(검토결과 조치) ① 각 기관의 장은 보안성 검토결과를 통보받은 경우 검토결과를 반영하여 보안대책을 보완하여야 한다.

② 보안성 검토 기관의 장은 제1항에 따른 보안성 검토결과 반영여부를 확인하기 위하여 현장 점검을 실시할 수 있다.

제19조(현황 제출) 정보보안담당관은 전년도에 실시한 해당 기관 및 소속·산하기관의 정보화 사업에 대한 보안성 검토결과 현황을 매년 1월 25일까지 국가정보원장에게 제출하여야 한다.

제3절 제품 도입

제20조(정보통신제품 도입) ① 각 기관의 장은 정보 및 정보통신망 등을 보호하기 위하여 보안기능이 있는 다음 각 호에 해당하는 정보통신제품을 도입할 수 있다.

1. [별표 1] 안전성 검증필 제품 목록에 등재되어 있는 제품

2. 비밀이 아닌 업무자료의 암호·복호화를 목적으로 한 경우 [별표 2] 암호가 주기능인 제품 도입요건을 만족하는 제품
 3. 제1호 및 제2호에 해당하지 않는 정보통신제품 중에서 국가정보원장이 별도로 공지하는 도입요건을 만족하는 제품
 4. 제품유형의 특성상 보안기능의 비중이 미미하여, 각 기관의 장이 자유롭게 도입·운용이 가능한 ‘단순 보안기능 제품유형’으로 국가정보원장이 공지한 제품
 5. 「국가 정보보안 기본지침」 제97조의3 제2항에 따라 취약 정보통신제품을 긴급 대체하기 위하여 도입하는 제품
- ② 제1항제3호에 해당하는 제품은 실제 적용·운용 이전에 제2장제5절에 따른 보안적합성 검증을 받아야 한다.
- ③ 제1항제5호에 해당하는 긴급 대체 제품을 도입한 기관의 장은 빠른 시일 내에 원(原) 제품과 동일 수준의 안전성 확인이 이루어질 수 있도록, 대체 제품에 대하여 제1항제1호 및 제2호에 따른 도입요건을 갖추도록 하거나 제3호 및 제2장제5절에 따른 보안적합성 검증 절차를 거치도록 하여야 하며, 필요시 국가정보원장에게 추가적인 검증을 요청할 수 있다.

제21조(암호가 주기능인 제품 도입요건) 각 기관의 장은 정보통신망을 이용하여 유통·보관되는 중요자료를 보호하기 위하여 암호가 주기능인 제품을 도입·운용하고자 할 경우 [별표 2]에 따른 암호가 주기능인 제품 도입요건을 준수하여야 한다.

제22조(도입현황 제출) ① 각 기관의 장은 매 분기 말에 해당 분기 내에 도입한 제21조 및 제22조에 따른 모든 제품에 대하여 [서식 제2호]에 따른 정보통신제품 도입현황과 국가정보원장이 정보공유시스템을 통해 배포하는 제품유형별 운용점검사항을 정보보안담당관에게 제출하여야 한다.

② 정보보안담당관은 제1항에 따라 제출받은 현황 등을 국가정보원장에게 제출하여야 한다.

제23조(상용소프트웨어 도입) 각 기관의 장은 「상용소프트웨어 제3자단가계약 추가특수조건」(조달청 지침) 제2조제2호에 따른 제3자단가계약으로 상용소프트웨어를 도입하고자 할 경우, 같은 지침 제10조제4항에 따른 판매중지 여부에 유의하여야 한다.

제4절 사업 수행

제24조(계약 특수조건) ① 각 기관의 장은 「국가를 당사자로 하는 계약에 관한 법률 시행령」 제76조제1항제3호다목에 따른 정보통신망 또는 정보시스템 구축 및 유지보수 등의 계약 이행과정에서 정보통신망 또는 정보시스템에 허가 없이 접속하거나 무단으로 정보를 수집할 수 있는 비인가 프로그램을 설치하거나 그러한 행위에 악용될 수 있는 정보통신망 또는 정보시스템의 약점을 고의로 생성 또는 방치하는 행위 등을 금지하는 내용의 계약 특수조건을 계약서에 명시하여야 하며 계약기간(하자 보증기간을 포함한다) 내에 발생한 보안약점 등에 대해서는 계약업체로 하여금 개선 조치하도록 하여야 한다.

② 각 기관의 장은 필요한 경우 계약업체로부터 제1항과 관련한 행위가 없다는 대표자 명의의 확인서를 요구할 수 있다.

제25조(용역업체 보안) ① 각 기관의 장은 용역업체에 정보화사업을 발주할 경우 다음 각 호의 보안사항을 준수하도록 계약서에 명시하여야 한다.

1. 제13조제1항 각 호에 따른 제안요청서에 포함된 사항

1의2. 제28조에 따른 원격지 개발, 제28조의2에 따른 원격지에서의 온라인 개발, 제44조에 따른 온라인 유지보수를 허용할 경우 보안 준수사항

2. 소프트웨어 개발보안에 필요한 사항

3. 사업 참여직원의 보안준수 사항과 위반 시 손해배상 책임에 관한 사항

4. 사업 수행과 관련한 보안교육, 보안점검 및 사업기간 중 참여인원 임의 교체 금지

5. 정보통신망 구성도·IP현황 등 용역업체에 제공하는 자료는 자료 인계 인

- 수대장을 비치, 보안조치 후 인계·인수하고 무단 복사 및 외부반출 금지
6. 업체의 노트북·휴대용 저장매체 등 관련 장비는 반출·입시마다 악성코드 감염 여부, 누출금지정보 무단 반출여부 등 점검
 7. 사업 종료 시 업체의 노트북·휴대용 저장매체 등 관련 장비는 저장자료 복구가 불가하도록 완전 삭제
 8. 사업 종료 시 누출금지정보 전량 회수
 9. 그 밖에 각 기관의 장이 보안관리가 필요하다고 판단하는 사항 또는 국가정보원장이 보안조치를 권고하는 사항
- ② 각 기관의 장은 비밀 및 중요 용역사업을 수행할 경우 용역업체 참여인원이 다음 각 호에 해당되는 사실을 알게 된 경우 교체를 요구하여야 한다.
1. 「국가공무원법」 제33조제3호부터 제6의4호까지에 해당하는 사람
 2. 「국가를 당사자로 하는 계약에 관한 법률」 제27조제1항 각 호의 행위를 한 사람
- ③ 각 기관의 장은 다음 각 호에 따른 보안 준수사항의 이행여부를 정기 또는 수시로 점검(불시 점검을 포함한다)하고 미비점을 발견한 경우 용역업체로 하여금 시정 조치하도록 하여야 한다. 이 경우 정보화사업담당관이 점검한 후 그 결과를 정보보안담당관에게 통보하여야 한다.
1. 제1항에 따라 계약서에 명시된 보안 준수사항
 2. 제27조의2에 따른 발주기관 내 작업장소 보안 준수사항
 3. 제28조에 따른 원격지 개발보안 및 제28조의2에 따른 원격지에서의 온라인 개발 시 보안 준수사항
 4. 제51조에 따른 정보시스템 유지보수 및 제44조에 따른 온라인 유지보수 시 보안 준수사항
- ④ 정보보안담당관은 본청 각 부서 및 소속·산하기관에 대하여 용역업체 보안관리실태 점검을 실시할 수 있으며, 필요한 경우 국가정보원장에게 지원을 요청할 수 있다.
- ⑤ 각 기관의 장은 제3항 및 제4항에 따른 점검 결과, 용역업체 보안대책 준수가 미흡하고 시정조치가 어렵다고 판단할 경우 제28조에 따른 원격지 개발, 제28조의2에 따른 원격지에서의 온라인 개발 또는 제44조에 따른 온라인 유지

보수 허가를 취소할 수 있다.

⑥ 각 기관의 장은 제28조의2에 따른 원격지 개발, 제44조에 따른 온라인 유지보수를 허용하고자 할 경우에는 용역업체의 온라인 접속을 통제하기 위한 온라인 용역 통제시스템을 구축·운영하여야 한다.

⑦ 그 밖에 용역업체 보안과 관련한 사항은 국가정보원장이 배포한 「국가·공공기관 용역업체 보안관리 가이드라인」을 준수하여야 한다.

제26조(소프트웨어 개발보안) 각 기관의 장은 정보시스템을 개발할 경우 「전자정부법」 제45조 및 「행정기관 및 공공기관 정보시스템 구축·운영지침」(행정안전부 고시) 제50조부터 제53조까지에 따라 보안약점이 발생하지 아니하도록 개발(이하 "소프트웨어 개발보안"이라 한다)하고 정보시스템 감리 등을 통해 보안약점을 진단하여야 한다.

제27조(발주기관 내 작업장소 보안) ① 각 기관의 장은 발주기관 내(기관장이 임차한 외부 사무실을 포함한다) 용역업체 작업장소를 설치할 경우 보안 통제가 가능한 공간을 마련 운영하여야 한다.

② 발주기관 내 용역업체 작업장소에 설치 운영하는 정보통신망은 발주기관의 정보통신망과 분리 구성하여야 한다. 다만, 용역업체가 사업 수행을 위하여 발주기관 정보시스템 이용이 불가피할 경우에는 필요한 정보시스템에 한해 지정된 단말기로부터의 제한적 접근을 허용하는 등 보안대책을 수립·시행하여야 하며, 이 경우 내부망 정보시스템에 대한 접근 허용에 관하여는 정보보안담당관을 거쳐 국가정보원장과 사전 협의하여야 한다.

③ 작업장소 내 정보시스템은 용역사업 수행을 위해 필요한 경우 해당 정보화사업담당관의 보안통제 하에 인터넷에 연결할 수 있다. 다만, 제2항 단서에 따른 발주기관 정보시스템 접근용 단말기의 경우에는 인터넷 연결을 금지한다.

④ 각 기관의 장은 용역업체가 발주기관 내 작업장소에서 개발 작업을 수행하더라도 개발용 서버가 민간 클라우드컴퓨팅서비스를 이용하는 등으로 원격지에 위치할 경우 제28조에 따른 원격지 개발로 간주하고 제28조제1항에 따른 보안대책을 수립·시행하여야 한다.

제28조(원격지 개발보안) ① 각 기관의 장은 「소프트웨어 진흥법」 제49조제3항 및 제4항, 「소프트웨어사업 계약 및 관리감독에 관한 지침」 제14조에 따라 용역업체가 발주기관 이외의 장소(이하 "원격지"라 한다)에서 개발 작업(유지보수는 제외한다)을 수행하고자 요청할 경우 제13조제1항제1호에 따른 용역업체 작업장소에 대한 보안요구사항 등을 포함한 관리적·기술적 보안대책을 수립·시행하여야 한다. 이 경우 정보화사업담당관은 보안대책을 수립한 후 정보보안담당관의 승인을 받아야 한다.

② 원격지 내 정보시스템은 개발 작업을 위하여 필요한 경우 해당 정보화사업담당관의 보안통제 하에 인터넷에 연결할 수 있다.

제28조의2(원격지에서의 온라인 개발) 제28조에 따른 원격지 개발에서 각 기관의 장이 필요하다고 판단하고 용역업체가 다음 각 호에 따른 보안대책에 서면으로 동의하는 경우에 한하여, 각 기관의 장은 용역업체에게 원격지에서 인터넷을 통해 발주기관 정보시스템에 온라인 접속한 상태의 개발 작업을 허용할 수 있다.

1. 지정된 단말기에서만 접속 및 해당 단말기에 대한 접근인원 통제
2. 지정 단말기는 제3호에 따른 온라인 용역 통제시스템 접속 전용(專用)으로 운용하고 다른 목적의 인터넷 접속은 차단
3. 발주기관 내 온라인 용역 통제시스템을 경유하여 개발에 필요한 정보시스템에 접속하는 등 소통구간 보호·통제
4. 접속사실이 기록된 로그기록을 1년 이상 보관
5. 계약 시행일로부터 종료 후 30일이 경과하는 날까지의 기간 중에 발주기관, 발주기관의 상급기관 및 국가정보원장의 정기 또는 수시 보안점검(불시 점검을 포함한다) 수검
6. 기타 국가정보원장이 배포한 「국가·공공기관 용역업체 보안관리 가이드라인」에서 제시된 온라인 개발에 관련된 보안대책의 준수

제29조(소프트웨어 산출물 제공) ① 각 기관의 장은 용역업체가 「소프트웨어

진흥법」 제59조 및 「(계약예규)용역계약일반조건」 (기획재정부 계약예규) 제56조에 따른 지식재산권을 행사하기 위하여 소프트웨어 산출물의 반출을 요청할 경우 제안요청서 또는 계약서에 명시된 누출금지정보에 해당하지 아니하면 제공하여야 한다.

② 각 기관의 장은 제1항에 따라 소프트웨어 산출물을 용역업체에 제공할 경우 업체의 노트북·휴대용 저장매체 등 관련 장비에 저장되어 있는 누출금지정보를 완전 삭제하여야 하며 업체로부터 누출금지정보가 완전 삭제되었다는 대표자 명의의 확인서를 받아야 한다.

③ 각 기관의 장은 용역업체가 소프트웨어 산출물을 제3자에게 제공하고자 할 경우 제공하기 이전에 해당 기관의 장에게 승인을 받도록 하여야 한다.

④ 그 밖에 소프트웨어 산출물 제공과 관련한 사항은 「소프트웨어사업 계약 및 관리감독에 관한 지침(과학기술정보통신부 고시)」 제32조를 준수하여야 한다.

제30조(누출금지정보 유출시 조치) ① 각 기관의 장은 용역업체가 제안요청서 또는 계약서에 명시된 누출금지정보를 유출한 사실을 인지한 경우 업체를 대상으로 계약 위반에 따른 조치를 취하여야 한다. 이 경우 용역업체의 누출금지정보 유출 사실을 인지한 정보화사업담당관 또는 사업과 관계된 공무원등은 즉시 소속된 기관의 장에게 보고하여야 한다.

② 제1항에 따라 용역업체의 누출금지정보 유출 사실을 인지하거나 보고를 받은 기관의 장은 그 사실을 정보보안담당관 및 국가정보원장에게 통보하여야 하고 직접 또는 관계 상급기관의 장을 통하여 「국가를 당사자로 하는 계약에 관한 법률 시행령」 제76조에 따라 입찰 참가자격 제한 등 관련조치를 취하여야 한다.

제5절 보안적합성 검증

제31조(보안적합성 검증대상 제품) 각 기관의 장은 제20조제1항제3호에 따른

보안기능이 있는 정보통신제품을 도입하는 경우 실제 적용·운용 이전에 안전성을 확인하기 위하여 보안적합성 검증을 받아야 한다.

제32조(검증 기관 및 신청) ① 각 기관은 제31조에 따른 보안적합성 검증을 받고자 할 경우 다음 각 호의 기관(이하 "검증기관"이라 한다)의 장에게 검증을 신청하여야 한다.

1. 본청 각 부서 및 소속기관 : 국가정보원

2. 산하기관 : 정보보안담당관

② 제1항제2호에도 불구하고 각 기관의 장은 필요하다고 판단하는 경우 정보보안담당관과 협의하여 자체적으로 검증을 실시할 수 있다.

제33조(검증 신청 시 제출물) ① 각 기관의 장은 보안적합성 검증을 신청할 경우 검증기관의 장에게 [별표 3] 보안적합성 검증 신청 시 제출물에 해당하는 문서 등을 제출하여야 한다.

② 제1항에 따라 검증을 신청한 기관의 장은 검증기관의 장이 필요하다고 판단하여 추가 자료를 요청할 경우 이를 제출하여야 한다.

제34조(안전성 시험) ① 검증기관의 장은 제33조에 따라 제출된 문서 내용의 적절성을 검토한 후 검증대상 제품에 대하여 보안기능 정상 동작여부 등 안전성을 시험한다. 이 경우 검증기관의 장은 시험에 필요한 사항을 추가로 요청할 수 있다.

② 검증기관은 제1항에 따른 안전성 시험 등 관련 업무를 시험기관에 의뢰할 수 있다.

③ 검증기관의 장은 검증대상 제품의 제출 지연 등의 사유로 시험을 진행할 수 없을 경우 검증 절차를 중단할 수 있다.

제35조(검증결과 통보 및 조치) ① 검증기관의 장은 제34조에 따른 시험 결과를 토대로 제품의 안전성을 종합 검토한 검증결과를 검증신청 기관의 장에게 통보한다.

② 제1항에 따라 검증결과를 통보받은 기관의 장은 해당 조치를 실시하고 그 결과를 검증기관의 장에게 통보하여야 한다.

제36조(형상변경 및 용도변경시 조치) 각 기관의 장은 보안적합성 검증이 완료된 제품의 보안기능 등 형상 변경이 필요하거나 도입 목적 이외 용도로 운용이 필요한 경우 검증기관의 장과 협의하여 추가 검증 등 필요한 조치를 취하여야 한다.

제 4 장 정보통신망 및 정보시스템 보안

제1절 정보통신망 보안

제37조(내부망·인터넷망 분리) ① 각 기관의 장은 내부망과 기관 인터넷망을 분리·운영하여야 한다.

② 각 기관의 장은 내부망과 기관 인터넷망을 분리·운영하고자 할 경우 다음 각 호의 사항을 포함한 보안대책을 수립·시행하여야 한다.

1. 침입차단·탐지시스템 설치 등 비(非)인가자 침입 차단대책
2. 네트워크 접근관리시스템 설치 등 비(非)인가 장비의 내부망 접속 차단 대책
3. 내부망 정보시스템의 인터넷 접속 차단대책
4. 내부망과 기관 인터넷망 간 안전한 자료전송 대책
5. 기타 국가정보원장이 배포한 「국가·공공기관 업무전산망 분리 및 자료 전송 보안가이드라인」에서 제시하는 보안대책

③ 각 기관의 장은 정보시스템에 부여되는 IP주소를 체계적으로 관리하여야 하며 비(非)인가자로부터 내부망을 보호하기 위하여 네트워크주소변환기(NAT)를 이용하여 사설 IP주소체계를 구축·운영하여야 한다. 또한 IP주소별로 정보시스템 접속을 통제하여 비(非)인가 기기에 의한 내부망 접속을 차단

하여야 한다.

④ 각 기관의 장은 분리된 내부망과 기관 인터넷망 간 자료 전송을 위한 접점이 불가피한 경우 다음 각 호의 사항을 포함한 보안대책을 수립·시행하여야 한다.

1. 침입차단·탐지시스템 설치·운용
2. 내부망과 기관 인터넷망 간 접점 최소화
3. 내부망과 기관 인터넷망 간 일방향 전송장비 등을 이용한 자료전송체계를 구축·운영하고 원본파일은 3개월 이상, 전송로그는 6개월 이상 유지
4. 정기적으로 전송실패 기록을 확인하고 악성코드 유입여부 등 점검
5. 내부망 자료를 기관 인터넷망으로 전송할 경우 부서 분임정보보안담당관 또는 결재권자의 사전 또는 사후 승인절차 마련

⑤ 각 기관의 장은 인터넷 PC에서 업무자료의 저장을 금지하기 위한 기술적·관리적 방안을 강구하여야 한다.

⑥ 각 기관의 장은 제1항에도 불구하고 예산 부족 등 사유로 부득이한 경우 국가정보원장과 협의하여 내부망과 기관 인터넷망을 분리하지 아니할 수 있다. 이 경우 다음 각 호의 사항을 포함한 보안대책을 수립·시행하여야 한다.

1. 정보시스템 및 개별사용자 PC 영역 등에 대한 접근 통제대책
2. 인터넷 PC의 악성코드 감염 최소화를 위한 인터넷 사용 통제대책
3. 인터넷 PC의 악성코드 감염에 따른 내부망으로의 피해확산 차단대책
4. 사이버공격 탐지·대응 등 안전한 업무환경을 위한 보호대책

⑦ 각 기관의 장은 내부망과 기관 인터넷망의 IP주소 현황을 정기적으로 확인하고 갱신하여야 한다.

제38조(클라우드컴퓨팅 보안) ① 각 기관의 장은 「클라우드컴퓨팅 발전 및 이용자 보호에 관한 법률」 제12조에 따라 클라우드컴퓨팅[「행정기관 및 공공기관 정보자원 통합기준(행정안전부 고시)」 제2조제5호에 따른 공공클라우드센터를 포함한다]을 자체 구축·운영하고자 할 경우 국가정보원장이 배포한 「국가·공공기관 클라우드 컴퓨팅 보안가이드라인」에 명시된 기관 자체 클라우드컴퓨팅 구축 보안기준에 따라 보안대책을 수립·시행하여야 한다.

② 각 기관의 장은 「전자정부법」 제54조의2 및 「클라우드컴퓨팅 발전 및

이용자 보호에 관한 법률」 제20조에 따라 민간 클라우드컴퓨팅서비스(「행정기관 및 공공기관 정보자원 통합기준(행정안전부 고시)」 제2조제4호에 따른 민간클라우드센터를 포함한다)를 이용하고자 할 경우 다음 각 호에 해당하는 사항을 준수하여야 한다.

1. 국내에 위치한 정보시스템에 데이터가 저장되는 서비스로서 일반 이용사용 서비스 영역과 물리적으로 분리되어 제공되는 서비스 영역(이하 "공공 전용(專用) 민간클라우드"라 한다)에 한하여 활용
2. 과학기술정보통신부장관이 고시한 「클라우드컴퓨팅서비스 정보보호에 관한 기준」에 부합하는 서비스 선정
3. 국가정보원장이 배포한 「국가·공공기관 클라우드 컴퓨팅 보안가이드라인」에서 제시하는 민간 클라우드컴퓨팅서비스 이용 보안기준 및 행정안전부장관이 배포한 「행정·공공기관 민간 클라우드 이용 가이드라인」에 따른 절차 이행
- ③ 각 기관의 내부망과 연동된 공공 전용(專用) 민간클라우드에는 이 지침을 적용함에 있어 각 기관의 내부망으로 본다.
- ④ 각 기관의 기관 인터넷망과 연동된 공공 전용(專用) 민간클라우드에는 이 지침을 적용함에 있어 각 기관의 기관 인터넷망으로 본다.
- ⑤ 제2항에 따라 민간 클라우드컴퓨팅서비스를 이용하는 기관의 장은 클라우드컴퓨팅서비스제공자에 의하여 누출금지정보가 유출된 경우 제30조에 따른 조치를 취하여야 한다.

제39조(보안·네트워크장비 보안) ① 각 기관의 장은 침입차단·탐지시스템, 스위치·라우터 등 기관 정보통신망 구성 또는 정보보안 정책 전반에 영향을 미치는 보안·네트워크장비를 설치·운용하고자 할 경우 다음 각 호의 사항을 포함한 보안대책을 수립·시행하여야 한다.

1. 물리적으로 안전한 장소에 설치하여 비(非)인가자의 무단접근 통제
 2. 콘솔에서 관리함을 원칙으로 하되, 다음 각 목의 경우 청사 내 지정 단말기로부터의 접속·관리 허용
- 가. 장비 관리자의 접속

- 나. 제27조제2항 단서에 따른 발주기관내 용역업체 작업장소에서의 접속
3. 최초 설치할 경우 디폴트(default) 계정은 삭제하거나 변경 사용하고 장비 관리를 위한 관리자 계정을 별도로 생성·운영
 4. 불필요한 서비스 포트와 개별사용자 계정은 차단 및 삭제
 5. 펌웨어 무결성과 컴퓨터 운영체제·소프트웨어의 취약점 및 버전 업데이트 여부를 정기적으로 점검하고 최신 버전으로 유지
- ② 보안·네트워크장비 관리자는 로그기록을 1년 이상 유지하여야 하고 비(非)인가자의 접속여부를 정기적으로 점검하여 그 결과를 정보보안담당관에게 통보하여야 한다.
- ③ 보안·네트워크장비 관리자는 침입차단·탐지시스템의 침입차단·탐지규칙(rule)의 생성 근거를 유지하고 정기적으로 필요성 여부를 점검·갱신하여야 한다.

제40조(무선랜 보안) ① 각 기관의 장은 내부망을 제외한 정보통신망에서 다음 각 호의 경우와 같이 청사 내에 무선랜(WiFi)을 구축·운영할 수 있다.

1. 기관 인터넷망에 중계기(AP)를 설치하여 해당 기관의 장이 지급한 단말기의 접속만을 허용하는 업무용 무선랜
2. 상용 인터넷망에 중계기(AP)를 설치하여 소속 부서의 분임정보보안담당관의 승인을 받은 후 반입한 공무원등의 개인 소유 이동통신단말기의 접속만을 허용하는 무선랜

3. 상용 인터넷망에 중계기(AP)를 설치한 외부인 전용(專用) 무선랜

② 각 기관의 장은 제1항에 따라 무선랜을 구축·운영하고자 할 경우 국가정보원장이 배포한 「국가·공공기관의 무선랜 구축 및 RFID 보안가이드라인」을 준수하여 보안대책을 수립·시행하여야 한다.

③ 제2항에 따른 보안대책을 수립할 경우 제1항제1호 및 제2호에 따른 무선랜에 대하여는 다음 각 호의 사항을 포함하여야 한다.

1. 네트워크 이름(SSID) 브로드캐스팅(broadcasting) 금지
2. 추측이 어렵고 복잡한 네트워크 이름(SSID) 사용
3. WPA2 이상(256비트 이상)의 암호체계를 사용하여 소통자료 암호화

4. 비(非)인가 단말기의 무선랜 접속 차단 및 무선랜 이용 단말기를 식별하기 위한 IP주소 할당기록 등 유지
 5. IEEE 802.1X, AAA(Authentication Authorization Accounting) 등의 기술에 따라 상호 인증을 수행하는 무선랜 인증제품 사용
 6. 무선침입방지시스템 설치 등 침입 차단대책
 7. 기관의 내부망 정보시스템 또는 인접해 있는 다른 기관의 정보시스템이 해당 무선랜에 접속되지 아니하도록 하는 기술적 보안대책
 8. 그 밖에 무선랜 단말기·중계기(AP) 등 구성요소별 분실·탈취·훼손·오용 등에 대비한 관리적·물리적 보안대책
- ④ 부서 분임정보보안담당관은 제2항 및 제3항에 따른 보안대책의 적절성을 수시로 점검·보완하여야 한다.

제41조(이동통신망 보안) ① 각 기관의 장은 이동통신망(HSDPA·WCDMA·LTE·5G 등)을 이용하여 시스템을 구축하거나 중요자료를 소통하고자 할 경우 암호화 및 비인가 단말기의 이동통신망 접속 차단 등 기술적 보안대책을 수립·시행하여야 한다.

② 각 기관의 장은 제1항에 따라 이동통신망을 이용한 시스템을 구축·운용할 경우 해당 기관의 정보통신망과 혼용되지 않도록 하여야 한다.

제42조(영상회의 보안) ① 각 기관의 장은 영상회의시스템을 구축·운용하고자 할 경우 통신망(국가정보통신망·전용(專用)선·인터넷 등) 암호화 등 보안대책을 수립·시행하여야 한다.

② 기타 영상회의시스템 보안과 관련한 사항은 국가정보원장이 배포한 「안전한 정보통신 환경 구현을 위한 네트워크 구축 가이드라인」을 준수하여야 한다.

③ 각 기관의 장은 다음 각 호의 구분에 따라 상용 소프트웨어에 탑재된 영상회의 서비스를 이용할 수 있다.

1. 비공개 업무자료를 취급하거나 회의 내용이 비공개 업무자료에 준하다고 판단할 경우 : 영상·음성·업로드 데이터가 국내 서버로만 전송되는 상용

영상회의 소프트웨어(이하 "국내 영상회의 솔루션"이라 한다)를 활용

2. 공개 업무자료를 취급하거나, 회의 내용이 공개 업무자료에 준하다고 판단할 경우 : 국내 영상회의 솔루션 또는 그 밖의 영상회의 소프트웨어를 활용

④ 전항 제1호에도 불구하고, 각 기관의 장은 다음 각 호의 어느 하나에 해당하는 등 정당한 사유가 있는 경우 국가정보원장과 협의하여 국내 영상회의 솔루션 외의 소프트웨어를 일시적 또는 정기적으로 활용할 수 있다.

1. 안보·국익상 필요한 외국기관(외국군을 포함한다)과의 영상회의 시에 상대방이 국내 영상회의 솔루션을 활용할 수 없거나, 상대방이 국내 영상회의 솔루션 외의 소프트웨어 활용을 제안할 경우

2. 정책자문 등의 목적으로 민간인과 영상회의 시에 상대방이 국내 영상회의 솔루션을 활용할 수 없는 경우

⑤ 기타 영상회의 보안과 관련한 사항은 국가정보원장이 배포한 「원격업무 통합보안매뉴얼」을 준수하여야 한다.

제43조(인터넷 사용제한) ① 각 기관의 장은 국가비상사태 및 대형 재해·재난의 발생, 사이버공격 등으로부터 정보통신망과 정보시스템의 정상적인 운영을 보장하기 위하여 소속 공무원등에 대한 인터넷 사용을 일부 제한할 수 있다.

② 각 기관의 장은 기관 인터넷망의 효율적인 운영 관리 및 악성코드 유입 차단을 위하여 게임·음란·도박 등 업무와 관련이 없는 인터넷 이용을 차단하여야 하며, 악성코드 유입 차단을 위하여 필요할 경우 제55조제4항에 따른 상용 정보통신서비스의 접속을 제한할 수 있다.

제44조(재외사무소 정보보안 점검) ① 정보보안담당관은 외국에 개설·운영하는 사무소의 정보통신망 및 정보시스템에 대한 보안관리 실태를 점검하고 취약요인을 개선하도록 하여야 한다.

② 정보보안담당관은 제1항에 따른 보안관리 실태 점검을 위하여 필요한 경우 국가정보원장에게 중점 점검사항, 전문인력 지원 등 협조를 요청할 수 있다.

제2절 정보시스템 보안

- 제45조(정보시스템 보안책임)** ① 각 기관의 장은 정보시스템(PC·서버·네트워크장비·정보통신기기 등을 포함한다)을 도입·운용할 경우 해당 정보시스템에 대하여 관리자 및 관리책임자를 지정·운영하여야 한다.
- ② 정보시스템 관리자 및 관리책임자는 서버·네트워크장비 등 부서가 공동으로 사용하는 정보시스템의 운용·관리에 대한 보안책임을 진다.
- ③ 정보시스템 관리책임자는 정보시스템을 실제 운용하는 부서의 장이 되며 관리책임자는 [서식 제3호] 및 [서식 제4호]에 따른 정보시스템 관리대장을 수기 또는 전자적으로 작성·관리하여야 한다.
- ④ 정보시스템 관리책임자는 해당 부서의 [서식 제3호] 및 [서식 제4호]에 따른 정보시스템 관리대장에 정보시스템의 최종 변경 현황을 유지하여야 하며 사본 1부를 정보보안담당관에게 제출하여야 한다.
- ⑤ 정보보안담당관은 정보시스템 운용과 관련하여 보안취약점을 발견하거나 보안대책 수립이 필요하다고 판단하는 경우 개별사용자, 정보시스템 관리자 및 관리책임자에게 개선 조치를 요구할 수 있으며 조치가 완료될 때까지 정보시스템의 운용을 일시 제한할 수 있다.

- 제46조(정보시스템 유지보수)** ① 각 기관의 장은 정보시스템의 유지보수와 관련한 절차, 주기, 문서화 등과 관련한 사항을 자체 내규(또는 지침 등)에 포함하여야 한다. 정보시스템의 유지보수 절차 및 문서화를 수립할 경우 고려사항은 다음 각 호와 같다.

1. 유지보수 인원에 대한 보안서약서 집행, 보안교육 등을 포함한 유지보수 인가 절차를 마련하고 인가된 인원만 유지보수에 참여
2. 결함이 의심되거나 발생한 결함, 예방 및 유지보수에 대한 기록 유지
3. 유지보수를 위하여 정보시스템을 원래 설치장소에서 다른 장소로 이동할 경우 통제수단 마련
4. 유지보수 일시 및 담당자 인적사항, 출입통제 조치사항, 작업수행 내용

등 기록 유지

- ② 정보시스템 관리자는 용역업체 등이 유지보수와 관련한 장비·도구 등을 제27조제1항에 따른 발주기관 내 용역업체 작업장소로 반출·입할 경우 악성 코드 감염여부 및 자료 무단 반출여부 확인 등 보안조치를 실시하고 그 결과를 분임정보보안담당관에게 제출하여야 한다.
- ③ 정보시스템 관리자는 직접 또는 용역업체를 활용하여 정보시스템을 유지보수할 경우 콘솔 또는 지정된 단말기로부터의 접속만을 허용하여야 한다.
- ④ 각 기관의 장은 소관 정보시스템에 대하여 중요도·가용성 등에 따라 등급을 분류하고 해당 등급에 맞게 정보 보존 및 관리, 장애관리, 보안관리 등을 수행하여야 한다.

제47조(지정 단말기를 통한 온라인 유지보수) ① 제43조제3항에 따른 지정된 단말기를 통해 유지보수를 함에 있어 각 기관의 장이 필요하다고 판단하고 용역업체가 다음 각 호에 따른 보안대책에 서면으로 동의하는 경우에 한하여, 각 기관의 장은 용역업체에게 내부망을 포함하여 소관 정보시스템(제39조제1항에 따른 보안·네트워크장비는 제외한다)에 대하여 인터넷을 통한 온라인 유지보수를 허용할 수 있다.

1. 지정된 장소에 설치된 지정된 단말기에서만 접속 및 해당 단말기에 대한 접근인원 통제
2. 지정 단말기는 제3호에 따른 온라인 용역 통제시스템 접속 전용(專用)으로 운용하고 다른 목적의 인터넷 접속은 차단
3. 발주기관 내 온라인 용역 통제시스템을 경유하여 유지보수 대상 정보시스템에 접속하는 등 소통구간 보호·통제
4. 접속사실이 기록된 로그기록을 1년 이상 보관
5. 유지보수 계약 시행일로부터 종료 후 30일이 경과하는 날까지의 기간 중에 발주기관, 발주기관의 상급기관 및 국가정보원장의 정기 또는 수시 보안점검(불시 점검을 포함한다) 수검
6. 기타 국가정보원장이 배포한 「국가·공공기관 용역업체 보안관리 가이드라인」에서 제시된 온라인 유지보수에 관련된 보안대책의 준수

- ② 전항 제2호 및 제3호에도 불구하고 온라인 용역 통제시스템이 구축되지 않은 각 기관의 장은 온라인 유지보수를 즉시 실시하지 않고서는 기관 업무수행에 현저한 손해가 있다고 예상되는 경우에는 인터넷망 정보시스템에 한하여 직접 접속하는 온라인 유지보수를 일시적으로 허용할 수 있다.
- ③ 기타 정보시스템 온라인 유지보수 보안과 관련한 사항은 제25조(용역업체 보안)를 준용한다.

제48조(서버 보안) ① 각 기관의 장은 서버를 도입·운용하고자 할 경우 사이버공격으로 인한 자료 절취 및 위·변조 등에 대비하여 다음 각 호의 사항을 포함한 보안대책을 수립·시행하여야 한다.

1. 서버 내 저장자료에 대하여 업무별·자료별 중요도에 따라 개별사용자의 접근권한 차등 부여
 2. 개별사용자별 자료 접근범위를 서버에 등록하여 인가여부를 식별하도록 하고 인가된 범위 이외 자료 접근통제
 3. 서버 운용에 필요한 서비스 포트 이외 불필요한 서비스 포트 제거 및 관리자용 서비스와 개별사용자용 서비스 분리·운용
 4. 관리자용 서비스 접속 시 특정 IP주소가 부여된 관리자용 단말기 지정·운용
 5. 서버 설정 정보 및 저장자료에 대한 정기적 백업 실시
 6. 데이터베이스에 대하여는 개별사용자의 직접 접속 차단, 개인정보 등 중요정보 암호화 등 데이터베이스별 보안조치 실시
- ② 서버 관리자는 제1항에 따른 보안대책의 적절성을 수시 확인하여야 하며 연 1회 이상 서버 설정 정보와 저장자료의 절취 및 위·변조 가능성 등 보안 취약점을 점검·보완하여야 한다.

제49조(공개서버 보안) ① 각 기관의 장은 외부인에게 공개할 목적으로 웹서버 등 공개서버를 구축·운용하고자 할 경우 내부망과 분리된 영역(DMZ)에 설치하여야 한다.

- ② 각 기관의 장은 비(非)인가자의 공개서버 저장자료 절취 및 위·변조, 분산 서비스거부(DDoS) 공격 등에 대비하여 침입차단·탐지시스템 및 DDoS 대응

장비 설치 등 보안대책을 수립·시행하여야 한다.

③ 공개서버 관리자는 비(非)인가자의 공개서버 내 비공개 정보에 대한 무단 접근을 방지하기 위하여 서버에 접근할 수 있는 개별사용자를 제한하고 불필요한 계정은 삭제하여야 한다.

④ 공개서버 관리자는 공개서버 서비스에 필요한 프로그램을 개발·시험하기 위하여 사용한 도구(컴파일러 등) 및 서비스와 관계가 없는 산출물은 개발 완료 후 삭제하여야 한다.

⑤ 기타 공개서버 보안과 관련한 사항은 제45조(서버 보안)를 준용한다.

제50조(로그기록 유지) ① 각 기관의 장은 정보시스템의 효율적인 통제·관리 및 사고 발생 시 추적 등을 위하여 로그기록을 유지·관리하여야 한다.

② 제1항에 따른 로그기록에는 다음 각 호의 사항이 포함되어야 한다.

1. 접속자, 정보시스템·응용프로그램 등 접속대상
2. 로그인·오프, 자료의 열람·출력 등 작업 종류 및 시간
3. 접속 성공·실패 등 작업 결과
4. 전자우편 사용 등 외부발송 정보 등

③ 정보시스템 관리자는 로그기록을 생성하는 정보시스템의 경우 시간 동기화 프로토콜(NTP) 적용 등을 통해 정확한 기록을 유지하여야 한다.

④ 정보시스템 관리자는 로그기록을 정기적으로 점검하고 점검 결과 비(非)인가자의 접속 시도, 자료의 위·변조 및 삭제 등 의심스러운 정황이나 위반한 사실을 발견한 경우 즉시 정보보안담당관에게 통보하여야 한다.

⑤ 정보시스템 관리자는 로그기록을 1년 이상 보관하여야 하며 로그기록의 위·변조 및 외부유출 방지대책을 수립·시행하여야 한다.

제51조(업무용 통신단말기 보안) ① 각 기관의 장은 업무용 통신단말기를 이용하여 업무자료 등 중요정보를 소통·관리하고자 할 경우 다음 각 호의 사항을 포함한 보안대책을 수립·시행하여야 한다.

1. 통신단말기에 대한 장치 및 개별사용자 인증
2. 제어신호 및 통화내용 등 데이터 암호화

3. 분실·탈취·훼손 등에 대비한 관리적·물리적·기술적 보안대책

② 각 기관의 장은 제1항에 따른 보안대책을 수립하기 위하여 국가정보원장에게 취약점 점검 및 기술 지원을 요청할 수 있다.

③ 각 기관의 장은 제1항제1호에 따른 통신단말기 개별사용자를 대상으로 인증 및 암호화에 필요한 디지털정보를 발급할 수 없을 경우 국가정보원장이 배포한 「정보통신기기 암호기술 적용지침」을 준수하여야 한다.

④ 각 기관의 장은 해당 기관의 주요 보직자가 안전한 통화를 위하여 사용하는 공용(公用) 휴대폰(이하 "안보폰"이라 한다)이 분실·훼손되지 않도록 현황을 관리하여야 한다. 이 경우 각 기관의 장은 국가정보원장이 예외로 허용하는 운용방식 이외에는 「국가 정보보안 기본지침」 제118조에 따라 보안대책을 수립·시행하여야 한다.

제52조(모바일 업무 보안) ① 각 기관의 장은 휴대폰·태블릿 PC 등을 이용한 모바일 업무환경(내부 행정업무, 현장 행정업무 및 대민서비스 업무 등)을 구축·운영하고자 할 경우 보안대책을 수립·시행하여야 한다.

② 기타 모바일 업무 보안과 관련한 사항은 국가정보원장이 배포한 「국가·공공기관 모바일 활용업무에 대한 보안가이드라인」을 준수하여야 한다.

제53조(사물인터넷 보안) ① 각 기관의 장은 사물인터넷을 이용한 시스템을 구축·운영하고자 할 경우 사물인터넷 기기 및 중요 데이터 등을 보호하기 위하여 보안대책을 수립·시행하여야 한다.

② 각 기관의 장은 사물인터넷을 이용한 시스템을 구축·운영하고자 할 경우 내부망과 분리하여야 한다. 다만, 내부망과 연동이 필요한 경우에는 망간 자료 전송제품 설치 등 보안대책을 수립하여야 한다.

③ 각 기관의 장은 사물인터넷 서비스를 위한 소프트웨어를 개발할 경우 제26조(소프트웨어 개발보안)를 준수하여야 한다.

④ 기타 사물인터넷 보안과 관련한 사항은 국가정보원장이 배포한 「국가·공공기관 사물인터넷(IoT) 보안가이드라인」을 준수하여야 한다.

제54조(원격근무 보안) ① 각 기관의 장은 소속 공무원등이 재택근무, 출장지 현장 근무 또는 파견 근무 시 인터넷을 통해 본인 인증을 거쳐 기관 정보시스템에 접속하여 온라인상으로 업무를 수행(이하 "원격근무"라 한다)하게 할 수 있다.

② 제1항에 따른 원격근무를 위해 접속할 수 있는 기관 정보시스템은 다음 각 호와 같다.

1. 기관 인터넷망에 위치한 서버 및 서버에서 구동되는 가상 PC
2. 제37조제2항제4호에 따른 방법을 통해 접속할 수 있는 내부망 서버 및 내부망 서버에서 구동되는 가상 PC

③ 제1항에 따른 원격근무로 취급할 수 있는 업무자료의 범위는 공개 및 비공개 업무자료로 한다.

④ 원격근무자는 각 기관의 장 등이 원격근무용 단말기(개인 소유의 정보통신 기기를 포함한다)의 보안을 위하여 취하는 다음 각 호의 조치에 적극 협조하여야 한다.

1. 사이버공격 등으로 인한 자료유출 사고 발생 시 각 기관의 장이 요청하는 점검
2. 소속된 기관에서 지급받은 단말기의 경우 제62조에 따른 단말기 보안대책 준수

⑤ 각 기관의 장은 원격근무자에게 제4항에 따른 보안조치 등이 포함된 보안서약서를 징구하고 직위·임무에 부합한 정보시스템 접근권한 부여 및 보직변경·퇴직 등 변동사항이 발생 시 접근권한 조정 등의 절차를 마련·시행하여야 한다.

⑥ 기타 원격근무 보안과 관련한 사항은 국가정보원장이 배포한 「원격업무 통합보안매뉴얼」을 준수하여야 한다.

제55조(국제회의 보안) ① 각 기관의 장은 중요 국제회의를 위하여 PC·노트북 등 정보시스템을 국외 현지에서 설치·운용하고자 할 경우 관련 정보·자료가 유출되지 아니하도록 다음 각 호의 사항을 포함한 보안대책을 수립·시행하여야 한다.

1. 설치장소에 대한 물리적 접근통제
 2. 정보시스템 접근 통제 및 분실 방지 등 보안관리
 3. 정보시스템 저장자료 암호화 등 자료 접근통제
 4. 전화기·팩스 등 통신장비에 대한 도청방지
- ② 국제회의 참가자는 회의 상대방이 제공한 PC·노트북·휴대용 저장매체 등 정보시스템을 사용하여서는 아니 된다.

제56조(저장매체 불용처리) ① 각 기관의 장은 정보시스템 또는 저장매체(하드 디스크·반도체 기반 저장장치(SSD) 등)를 외부수리·교체·반납·양여·폐기·불용 처리하고자 할 경우 정보시스템 및 저장매체에 저장된 자료가 외부에 유출되지 않도록 자료 삭제 등 보안조치를 실시하여야 한다. 이 경우 정보시스템 관리자 및 개별사용자는 분임정보보안담당관과 협의하여야 한다.

② 제1항에 따라 자료를 삭제할 경우 [별표 4]에 따라 저장매체별·자료별 차별화된 삭제 방법을 적용할 수 있다.

③ 비밀·대외비를 저장하거나 암호화 키를 저장한 저장매체는 소각·파쇄·용해 등의 방법으로 완전 파괴하여야 한다.

④ 기타 정보시스템 및 저장매체의 불용처리와 관련한 사항은 국가정보원장이 배포한 「정보시스템 저장매체 불용처리지침」을 준수하여야 한다.

제3절 자료 보안

제57조(비밀의 전자적 처리) ① 각 기관의 장은 「보안업무규정」에 따라 비밀의 생산, 분류, 보관, 열람, 출력, 송·수신, 이관, 파괴 등을 전자적으로 처리할 수 있다.

② 각 기관의 장은 비밀을 전자적으로 처리하는 전(全) 과정에서 기밀성, 무결성, 인증, 부인방지 등 보안성을 확보하여야 하며 이를 위하여 국가정보원장이 개발하거나 안전성을 확인한 암호자재를 사용하여야 한다.

③ 제1항에 따라 비밀을 전자적으로 처리할 경우 내부망과 기관 인터넷망이

물리적으로 분리된 기관은 내부망 PC에서 비밀을 전자적으로 처리할 수 있으며 그 밖의 기관은 내부망 및 기관 인터넷망과도 분리된 별도의 비밀 작업용 PC에서 처리하여야 한다.

④ 종이문서로 출력된 비밀의 관리에 관하여는 「보안업무규정」을 준수하여야 한다.

제58조(대외비의 전자적 처리) ① 각 기관의 장은 대외비를 전자적으로 처리하고자 할 경우에는 검증필 암호모듈을 사용하여 위조·변조·훼손 및 유출 등을 방지하기 위한 보안대책을 강구하여야 한다.

② 각 기관의 장은 업무와 관계되지 아니한 사람이 대외비를 열람, 복제·복사, 배부할 수 없도록 보안대책을 수립·시행하여야 한다.

제59조(비공개 업무자료 처리) ① 공무원등은 비공개 업무자료를 다음 각 호의 어느 하나에 해당하는 방법으로만 처리하여야 한다.

1. 소속 또는 근무중인 기관의 내부망 PC 및 서버에 작성 및 저장·보관
2. 소속 또는 근무중인 기관의 장이 지급한 휴대용 저장매체에 작성 및 저장·보관
3. 다음 각 목의 어느 하나에 해당하는 수단(이하 "업무자료 공식 소통수단"이라 한다)을 이용한 수·발신 또는 등재·열람
 - 가. 소속 또는 근무중인 기관의 장이 자체적으로 구축·운용하는 전자우편 시스템(이하 "기관 전자우편"이라 한다)
 - 나. 공무원등이 공동으로 사용할 목적으로 문화체육관광부장관이 구축·운용하는 전자우편시스템(이하 "공직자통합메일"이라 한다)
 - 다. 공무원등이 다른 공무원등과 자료를 공유하거나 소통하기 위하여 사용하는 전용(專用) 소프트웨어(이하 "공공 전용(專用) 메신저"라 한다)
 - 라. 국회사무처가 구축·운용하는 의정자료전자유통시스템 등 기관간 업무자료의 소통 또는 공동 활용을 위해 구축한 정보시스템
4. 그 밖에 다른 법규에 따라 허용되는 처리방법

② 공무원등은 제1항에도 불구하고 다음 각 호의 어느 하나에 해당하는 경우

소속 또는 근무중인 기관의 장이 지급한 인터넷 PC 또는 출장용 노트북을 이용하여 비공개 업무자료를 처리할 수 있다.

1. 업무자료 공식 소통수단의 발신 또는 등재 기능을 이용하여 제3조제14호 다목의 문장 또는 문구 작성
2. 업무자료 공식 소통수단의 수·발신 또는 등재·열람 과정에서의 일시적 저장
3. 제37조제6항에 따른 기관 인터넷망 PC에 작성·저장
4. 제42조제3항 및 제4항에 따라 영상회의 솔루션을 활용하여 비공개 업무자료의 화면 영상을 공유하기 위한 일시적 저장

③ 공무원등은 제1항에도 불구하고 다음 각 호의 어느 하나에 해당하는 경우 개인이 소유한 PC·휴대용 저장매체·휴대폰 등을 이용하여 비공개 업무자료를 처리할 수 있다.

1. 업무자료 공식 소통수단의 발신 기능 또는 등재 기능을 이용하여 제3조제14호다목의 문장 또는 문구 작성
2. 업무자료 공식 소통수단의 수·발신 또는 등재·열람 과정에서의 일시적 저장
3. 제50조에 따른 원격근무시스템에 접속하여 작성
4. 「감염병의 예방 및 관리에 관한 법률」 제34조제1항에 따른 감염병 위기관리 조치 등 대규모 질병·재난 발생 등 특별한 사정으로 재택근무를 명받았으나 소속 또는 근무중인 기관에 제59조제4항에 따른 원격근무시스템이 구축되지 아니한 경우
5. 제42조제3항 및 제4항에 따라 영상회의 솔루션을 활용하여 비공개 업무자료의 화면 영상을 공유하기 위한 일시적 저장
6. 국민의 생명·신체, 국가안보 및 공공의 안전 등을 위하여 긴급히 작성, 저장, 수·발신이 필요하다고 소속 또는 근무중인 기관의 장이 인정하는 경우

④ 공무원등은 제3항제4호 및 제5호에 해당하는 경우를 제외하고는 「정보통신망 이용촉진 및 정보보호 등에 관한 법률」 제2조제1항제2호에 따른 정보통신서비스(전자우편·메신저 등을 포함한다) 또는 국외에서 제공하는 이와 유사

한 서비스(이하 "상용 정보통신서비스"라 한다)를 이용하여 비공개 업무자료를 작성, 저장, 수·발신하여서는 아니 된다.

⑤ 공무원등은 제2항부터 제3항까지에 따라 작성·저장한 비공개 업무자료는 활용이 종료된 후에는 삭제하여야 한다.

제59조의2(특정 상황별 비공개 업무자료 처리) ① 모든 공무원등은 「국회법」 제128조제2항, 「국정감사 및 조사에 관한 법률」 제10조제2항, 「국회증언감정법」 제2조 및 제4조에 따라 국회·정부간 비공개 업무자료를 소통할 경우에는 우선적으로 제55조제1항제3호라목의 의정자료전자유통시스템을 활용하여 처리하여야 하며, 시스템 장애 등 부득이한 사유로 활용이 곤란할 경우에 한해 제55조에 허용된 다른 방법으로 처리할 수 있다.

② 감독·감사·조사 등의 관계 법령에 따라 비공개 업무자료를 제출받을 권한이 있는 공무원등은 업무자료를 제출할 상대방 공무원등에게 제55조에 위반되는 방법으로 자료 제출을 요구하여서는 아니 된다.

③ 공무원등이 자문 등의 목적으로 비공개 업무자료를 업무자료 공식 소통수단을 활용할 수 없는 민간인에게 발신하거나 민간인으로부터 수신 받고자 할 경우에는 공무원등의 소속 기관 전자우편 또는 공직자 통합메일을 활용해 발신하거나 수신 받아야 한다.

제60조(행정전자서명 인증서 등 관리) ① 공무원등은 비공개 업무자료를 처리하기 위하여 「전자정부법」 제29조에 따른 행정전자서명의 인증서(이하 "행정전자서명 인증서"라 한다)를 인터넷 PC 또는 개인이 소유한 PC·휴대용 저장매체·휴대폰 등에 저장·보관할 수 있다.

② 공무원등은 행정전자서명 인증서 및 인증서의 비밀번호, 기관 전자우편 또는 공직자통합메일의 비밀번호 등을 상용 정보통신서비스를 이용하여 수·발신하거나 저장·보관하여서는 아니 된다.

제61조(공개 업무자료 처리) 공무원등은 관계 법규에 위배되지 않는 범위 내에서 인터넷 PC나 개인이 소유한 PC·휴대용 저장매체·휴대폰(기관 청사 내에

서는 제67조제1항 각 호에 따라 반입한 경우를 말한다), 상용 정보통신서비스(기관 청사 내에서는 제41조제2항에 따른 제한이 없는 경우를 말한다) 등을 이용하여 공개 업무자료를 처리할 수 있다.

제62조(홈페이지 등 게시자료 보안) ① 각 기관의 장은 비공개 업무자료가 홈페이지 또는 외부 웹사이트(이하 "홈페이지 등"이라 한다.)에 무단 게시되지 않도록 게시자료의 범위, 자료의 게시방법 등을 규정한 자체 홈페이지 정보공개 보안지침을 수립·시행하여야 한다.

② 부서 분임정보보안담당관은 해당 부서에서 홈페이지 등에 업무자료를 게시하고자 할 경우 자료 내용을 사전 검토하여 비공개 업무자료가 게시되지 아니하도록 하여야 한다.

③ 부서 분임정보보안담당관은 소속 부서에서 운용하는 홈페이지에서 비공개 업무자료가 무단 게시되었는지 여부를 정기적으로 점검하여야 한다.

④ 각 기관의 장은 홈페이지 등에 비공개 업무자료가 무단 게시된 사실을 알게 된 경우 즉시 삭제 또는 차단 등 보안조치를 취하여야 한다.

제63조(정보통신망 현황자료 관리) ① 각 기관의 장은 다음 각 호에 해당하는 자료를 「공공기관의 정보공개에 관한 법률」 제9조제1항에 따른 비공개 대상 정보로 지정·관리하여야 한다.

1. 정보통신망 구성현황(IP주소 할당현황을 포함한다. 이하 본 조에서 같다.)
2. 정보시스템 운용현황
3. 취약점 분석·평가 결과물(「정보통신기반 보호법」 제9조에 따른 취약점 분석·평가결과를 포함한다.)
4. 주요 정보화사업 추진현황

② 각 기관의 장은 제1항에도 불구하고 다른 기관과 협력하여 정보통신망 및 정보시스템 운용 또는 정보보안업무를 수행할 필요가 있는 경우 제1항 각 호에 해당하는 자료를 다른 기관의 장에게 제공할 수 있다.

제64조(빅데이터 보안) ① 각 기관의 장은 빅데이터와 관련한 시스템을 구축·

운용하고자 할 경우 다음 각 호의 사항을 포함한 보안대책을 수립·시행하여야 한다.

1. 데이터의 수집 출처 확인 및 데이터 오·남용 방지
2. 데이터 수집을 위한 정보통신망 보안체계 수립
3. 수집된 데이터의 저장 및 보호체계 수립
4. 중요 데이터 암호화
5. 사용자별(데이터 제공자·수집자·분석요청자 및 분석결과 제공자 등) 권한부여 체계 수립
6. 데이터 파기절차 수립

② 그 밖에 빅데이터 보안과 관련한 사항은 개인정보보호위원회가 고시한 「개인정보의 안전성 확보조치 기준」 및 국가정보원장이 배포한 「국가·공공기관 빅데이터 보안 가이드라인」을 준수하여야 한다.

제4절 사용자 보안

제65조(개별사용자 보안) ① 각 기관의 장은 소관 정보통신망 또는 정보시스템의 사용과 관련하여 다음 각 호의 사항을 포함한 개별사용자 보안에 관한 절차 및 방법을 마련하여야 한다.

1. 직위·임무별 정보통신망 접근권한 부여 심사
2. 비밀 취급시 비밀취급 인가, 보안서약서 징구 등 보안조치
3. 암호자재 취급시 제103조에 따라 암호취급자 지정·관리
4. 보직변경, 퇴직 등 변동사항 발생시 정보시스템 접근권한 조정

② 개별사용자는 본인이 PC 등 정보시스템을 사용하거나 정보통신망에 접속하는 행위와 관련하여 스스로 보안책임을 진다.

제66조(단말기 보안) ① 개별사용자는 소속된 기관에서 지급받은 PC·노트북·휴대폰·스마트패드 등 단말기(이하 "단말기"라 한다) 사용과 관련한 일체의 보안관리 책임을 진다.

② 개별사용자는 단말기에 대하여 다음 각 호에 해당하는 보안대책을 준수하여야 한다.

1. CMOS · 로그인 비밀번호의 정기적 변경 사용
2. 단말기 작업을 일정 시간 중단시 비밀번호 등을 적용한 화면보호 조치
3. 최신 백신 소프트웨어 설치
4. 운영체제 및 응용프로그램에 대한 최신 보안패치 유지
5. 출처, 유통경로 및 제작자가 불분명한 응용프로그램의 사용 금지
6. 인터넷을 통해 자료(파일) 획득시 신뢰할 수 있는 인터넷사이트를 활용하고 자료(파일) 다운로드 시 최신 백신 소프트웨어로 검사 후 활용
7. 인터넷 파일공유 · 메신저 · 대화방 프로그램 등 업무상 불필요한 프로그램의 설치 금지 및 공유 폴더 삭제
8. 웹 브라우저를 통해 서명되지 않은 액티브-X 등이 다운로드 · 실행되지 않도록 보안 설정
9. 내부망과 기관 인터넷망이 분리된 기관의 인터넷 PC에서는 각급기관의 장이 정한 특별한 사유가 없는 한 문서프로그램을 읽기 전용(專用)으로 운용
10. 그 밖에 국가정보원장이 안전성을 확인하여 배포한 프로그램의 운용 및 보안권고문 이행

③ 부서 분임정보보안담당관은 정보보안담당관 총괄 하에 개별사용자의 제2항 각 호에 해당하는 보안대책의 준수여부를 정기적으로 점검하고 개선 조치하여야 한다.

제67조(계정 관리) ① 각 기관의 장은 개별사용자에게 소관 정보통신망 또는 공용(公用) 정보시스템의 접속에 필요한 사용자 계정(아이디)을 부여하고자 할 경우 다음 각 호에 해당하는 사항을 준수하여야 한다.

1. 개별사용자별 또는 그룹별 접근권한 부여
2. 외부인에게 계정을 부여하지 아니하되 업무상 불가피한 경우 기관의 장 책임 하에 보안조치 후 필요한 업무에 한하여 일정기간 동안 접속 허용
3. 특별한 사유가 없는 한 용역업체 인원에게 관리자 계정 부여 금지

4. 비밀번호 등 식별 및 인증 수단이 없는 사용자 계정은 사용 금지

② 공용(公用) 정보시스템 관리자는 개별사용자가 시스템 접속(로그온)에 5회 이상 실패할 경우 접속이 중단되도록 시스템을 설정하고 비(非)인가자의 침입 여부를 점검하여야 한다.

③ 공용(公用) 정보시스템 관리자는 개별사용자의 보직변경, 퇴직, 계약종료 등 변동사항이 발생할 경우 신속히 사용자 계정을 삭제하거나 부여된 접근 권한을 회수하여야 한다.

④ 공용(公用) 정보시스템 관리자는 사용자 계정 부여 및 관리의 적절성을 연 2회 이상 점검하고 그 결과를 정보보안담당관에게 통보하여야 한다

⑤ 공용(公用) 정보시스템 관리자는 제1항 및 제3항에 의한 접근권한 부여, 변경, 회수 또는 삭제 등에 대한 내역을 기록하고 3년 이상 보관하여야 한다.

제68조(비밀번호 관리) ① 개별사용자 및 공용(公用) 정보시스템 관리자는 각종 비밀번호를 다음 각 호에 해당하는 사항을 반영하고 숫자·문자·특수문자 등을 혼합하여 안전하게 설정하고 정기적으로 변경·사용하여야 한다.

1. 사용자 계정(아이디)과 동일하지 않은 것

2. 개인 신상 및 부서 명칭 등과 관계가 없는 것

3. 일반 사전에 등록된 단어의 사용을 피할 것

4. 동일한 단어 또는 숫자를 반복하여 사용하지 말 것

5. 사용된 비밀번호는 재사용하지 말 것

6. 동일한 비밀번호를 여러 사람이 공유하여 사용하지 말 것

7. 응용프로그램 등을 이용한 자동 비밀번호 입력기능을 사용하지 말 것

② 공용(公用) 정보시스템 관리자는 서버 등 정보시스템에 보관되는 비밀번호가 복호화 되지 아니하도록 일방향 암호화하여 저장하여야 한다.

③ 각 기관의 장은 공용(公用) 정보시스템에서 개별사용자를 식별 또는 인증하기 위하여 비밀번호에 갈음하거나 병행하여 지문인식 등 생체인증 기술 및 일회용 비밀번호 생성기(OTP) 등을 안전성 확인 후 사용할 수 있다. 이 경우 생체인증 정보는 안전하게 보관하여야 한다.

제69조(전자우편 보안) ① 각 기관의 장은 전자우편을 컴퓨터바이러스·트로이 목마 등 악성코드로부터 보호하기 위하여 백신 소프트웨어 설치, 해킹메일 차단시스템 구축 등 보안대책을 수립·시행하여야 한다.

② 개별사용자는 수신된 전자우편에 포함된 첨부파일이 자동 실행되지 아니하도록 기능을 설정하고 첨부파일을 다운로드할 경우 최신 백신 소프트웨어로 악성코드 은닉여부를 검사하여야 한다.

③ 개별사용자는 출처가 불분명하거나 의심되는 제목의 전자우편은 열람하지 말고 해킹메일로 의심될 경우 즉시 정보보안담당관에게 신고하여야 한다. 정보보안담당관은 해킹메일로 판단될 경우 국가사이버안전센터와 문화체육관광 사이버안전센터에 통보하여야 한다.

제70조(휴대용 저장매체 보안) ① 각 기관의 장은 휴대용 저장매체를 사용하여 업무자료를 보관하고자 할 경우 자료의 위·변조, 저장매체의 훼손·분실 등에 대비한 보안대책을 수립·시행하여야 한다.

② 각 기관의 장은 휴대용 저장매체 관리시스템을 운용하고자 할 경우 국가정보원장이 안전성을 확인한 제품을 도입하여야 한다.

③ 정보보안담당관은 개별사용자가 휴대용 저장매체를 PC·서버 등에 연결할 경우 자동 실행되지 아니하고 최신 백신 소프트웨어로 악성코드 감염여부를 자동 검사하는 등의 보안 정책을 수립·시행하도록 관리하여야 한다.

④ 휴대용 저장매체 관리자는 휴대용 저장매체를 비밀용·일반용으로 구분·관리하고 수량 및 보관 상태를 정기적으로 점검하며 외부 반출·입을 통제하여야 한다.

⑤ 휴대용 저장매체 관리자는 비밀이 저장된 휴대용 저장매체는 매체별로 비밀등급 및 관리번호를 부여하고 비밀관리기록부에 등재·관리하여야 한다. 이 경우 매체 전면에 비밀등급 및 관리번호가 표시되도록 하여야 한다.

⑥ 휴대용 저장매체 관리자는 비밀용 휴대용 저장매체를 다른 등급의 비밀용 또는 일반용으로 변경 사용하고자 할 경우 저장자료가 복구 불가하도록 완전 삭제 소프트웨어 등을 이용하여 삭제하여야 한다. 다만, 완전삭제가 불가할 경우 변경 사용하여서는 아니 된다.

- ⑦ 휴대용 저장매체 관리자는 휴대용 저장매체를 폐기·불용 처리하고자 할 경우 저장자료가 복구 불가하도록 완전삭제 소프트웨어 등을 이용하여 삭제하여야 한다. 다만, 완전삭제가 불가할 경우 파쇄하여야 한다.
- ⑧ 부서 분임정보보안담당관은 정보보안담당관 총괄 하에 소속 부서에 대하여 개별사용자의 휴대용 저장매체 무단 반출, 미(未)등록 휴대용 저장매체 사용여부 등 보안관리 실태를 정기적으로 점검하여야 한다.
- ⑨ 그 밖에 휴대용 저장매체 보안과 관련한 사항은 국가정보원장이 배포한 「USB메모리 등 휴대용 저장매체 보안관리지침」을 준수하여야 한다.

제71조(비인가 기기 통제) ① 공무원등은 다음 각 호의 경우를 제외하고는 개인 소유의 정보통신기기를 소속된 기관으로 무단 반입·사용하여서는 안 된다.

1. 보편적 통신 목적의 개인 소유 이동통신단말기(LTE·5G 등 이동통신망 접속기능이 있는 휴대폰·태블릿·스마트워치) : 반입하여 개인 용도로만 사용. 이 경우 반입 장비를 도크스테이션(dock station)·마우스·모니터·키보드 등 PC와 유사하게 활용토록 하는 장치와의 연결 사용 금지
 2. 제1호를 제외한 정보통신기기 : 제1호에 따른 반입·사용만으로는 보편적 통신 곤란 등 특별한 사정이 있는 경우에 한하여 소속 부서의 분임정보보안담당관을 거쳐 정보보안담당관의 승인을 받아 반입 후 개인 용도로만 사용
- ② 공무원등은 제1항 각 호에 따라 반입한 개인 소유의 정보통신기기를 소속된 기관의 내부망 및 기관 인터넷망(무선랜 형태를 포함한다)에 연결하여서는 안 되며, 내부망 및 기관 인터넷망 정보시스템을 다른 정보통신망에 연결하는 수단으로 사용하여서는 안 된다. 부서 분임정보보안담당관은 이에 대하여 수시로 점검하여야 한다.
- ③ 정보보안담당관은 개인 소유의 정보통신기기가 업무자료를 외부로 유출하는데 악용될 수 있거나 소속된 기관의 정보통신망 운영에 위해(危害)가 된다고 판단될 경우 반출·입 통제, 보안소프트웨어 설치 후 반입 등 보안대책을 수립·시행하여야 한다.

제72조(위규자 처리) 정보보안담당관은 정보보안감사, 사이버관제 중 정보보안 위규자를 적발하는 경우 [별표 5] 「정보보안 위규자 처리기준」에 의거하여 처리해야 하며, 위규사항 조치, 사유서 받기, 교육 실시, 조치결과 확인 등 재발방지를 위한 절차를 이행하여야 한다.

제 5 장 융합보안

제1절 정보통신시설 및 기기 보호

제73조(정보통신시설 보호대책) ① 각 기관의 장은 다음 각 호의 어느 하나에 해당하는 정보통신시설 및 장소를 「보안업무규정」 제34조에 따른 보호지역으로 지정·관리하여야 한다.

1. 암호실·정보통신실
2. 통합데이터센터
3. 암호자재 개발·설치 및 정비 장소
4. 보안관제센터, 백업센터 및 중요 정보통신시설을 집중 제어하는 국소
5. 그 밖에 보안관리가 필요하다고 인정되는 정보시스템 설치장소

② 각 기관의 장은 제1항에 따라 보호지역으로 지정된 정보통신시설 및 장소에 대한 보안대책을 수립하고자 할 경우 다음 각 호에 해당하는 사항을 포함하여야 한다.

1. 방재대책 및 외부로부터의 위해(危害) 방지대책
2. 상시 이용하는 출입문은 한 곳으로 정하고 이중 잠금장치 설치
3. 출입자 식별·인증 등을 위한 출입문 보안장치 설치 및 주·야간 감시대책
4. 휴대용 저장매체를 보관할 수 있는 용기 비치
5. 정보시스템의 안전지출 및 긴급파기 계획 수립
6. 관리책임자 및 자료·장비별 취급자 지정·운영
7. 정전에 대비한 비상전원 공급 및 시스템의 안정적 중단 등 전력관리 대책

8. 비상조명 장치 등 비상탈출 대책

9. 카메라 장착 휴대폰 등을 이용한 불법 촬영 방지대책

제74조(정보통신시설 출입관리) ① 각 기관의 장은 외부인이 정보통신시설을 방문할 경우 반드시 신원을 확인하고 보안교육 및 보안검색 후 출입을 허용하여야 한다.

② 각 기관의 장은 불가피한 경우를 제외하고는 정보통신시설에 대한 관람 및 견학은 지양하고 외국인의 출입은 금지한다. 다만, 외국인의 출입이 꼭 필요한 경우 국가정보원장과 사전 협의하여 출입을 허용할 수 있다.

제75조(영상정보처리기기 보안) ① 각 기관의 장은 업무상 목적으로 불특정 사람 또는 사물을 촬영한 영상을 유·무선 정보통신망으로 전송·저장·분석하는 CCTV·IP카메라·이동형 영상촬영장비·중계서버·관제서버·관리용 PC 등의 기기·장비(이하 "영상정보처리기기"이라 한다)를 설치·운용하고자 할 경우 운영자의 계정·비밀번호 설정 등 인증대책을 수립하고 특정 IP주소에서만 접속 허용 등 비(非)인가자 접근 통제대책을 수립·시행하여야 한다.

② 각 기관의 장은 영상정보처리기기를 통합·운용하는 시설(이하 "영상관제상황실"이라 한다)을 운영하고자 할 경우 영상관제상황실을 「보안업무규정」 제34조제2항에 따른 제한구역 또는 통제구역으로 지정·관리하고 출입통제 장치를 운용하여야 한다.

③ 영상정보처리기기 관리자는 영상정보처리기기를 인터넷과 분리·운용하여야 한다. 다만, 부득이하게 인터넷과 연결·사용하여야 할 경우 전송내용을 암호화하여야 한다.

④ 영상정보처리기기 관리자는 제1항부터 제3항까지와 관련한 보안대책의 적절성을 수시 점검·보완하여야 한다.

⑤ 기타 영상정보처리기기 보안과 관련한 사항은 국가정보원장이 배포한 「국가 공공기관 영상정보 처리기기 도입·운영 가이드라인」 및 「안전한 정보통신 환경 구현을 위한 네트워크 구축 가이드라인」을 준수하여야 한다.

제76조(RFID 보안) ① 각 기관의 장은 RFID시스템(대상이 되는 사물 등에 RFID 태그를 부착하고 전파를 사용하여 해당 사물 등의 식별정보 및 주변 환경정보를 인식하여 각 사물 등의 정보를 수집·저장·가공 및 활용하는 시스템을 말한다)을 구축하여 중요정보를 소통하고자 할 경우 다음 각 호의 사항을 포함한 보안대책을 수립·시행하여야 한다.

1. RFID시스템(태그 및 리더기를 포함한다) 분실·탈취 대비 및 백업 대책
2. 태그정보 최소화 대책
3. 장치 및 운용자 인증, 중요정보 암호화 대책

② RFID시스템 관리자는 제1항과 관련한 보안대책의 적절성을 수시 점검·보완하여야 한다.

③ 기타 RFID 보안과 관련한 사항은 국가정보원장이 배포한 「RFID 보안관리 실무매뉴얼」을 준수하여야 한다.

제77조(디지털복합기 보안) ① 각 기관의 장은 디지털복합기(디지털복사기 등도 포함한다. 이하 "복합기"라 한다)를 설치·운용하고자 할 경우 복합기 내 저장매체가 있거나 장착이 가능한 경우 자료유출을 방지하기 위하여 자료 완전삭제 또는 디스크 암호화 기능이 탑재된 복합기를 도입하여야 한다.

② 복합기 관리자는 제1항에 따라 복합기를 설치·운용할 경우 다음 각 호의 사항을 포함한 보안대책을 수립·시행하여야 한다.

1. 암호화 저장 기능이 있는 경우 해당 기능 사용
2. 정기적으로 저장된 작업 내용(출력·스캔 등) 완전 삭제
3. 공유 저장소 사용 제한 및 접근 제어
4. 고정 IP주소 설정 및 불필요한 서비스 제거

③ 복합기 관리자는 다음 각 호의 어느 하나에 해당하는 경우 복합기의 저장매체에 저장된 자료를 완전 삭제하여야 한다.

1. 복합기 사용연한이 경과하여 폐기·양여할 경우
2. 복합기 무상 보증기간 중 저장매체 또는 복합기 전체를 교체할 경우
3. 고장 수리를 위한 외부 반출 등의 사유로 해당 기관이 복합기의 저장매체를 통제 관리할 수 없는 장소로 이동할 경우

4. 그 밖에 저장자료의 삭제가 필요하다고 판단되는 경우

- ④ 복합기 관리자는 소모품 교체 등 복합기 유지보수를 할 경우 부서 분임정보보안담당관의 입회·감독 하에 실시하고 저장매체의 무단 교체 등을 예방하여야 한다.
- ⑤ 복합기 관리자는 복합기를 통해 내부망과 기관 인터넷망간 접점이 발생하지 않도록 보안대책을 수립·시행하여야 한다.
- ⑥ 정보보안담당관은 소속된 기관의 저장매체가 장착되어 있는 복합기 운용과 관련한 보안대책의 적절성을 수시 점검·보완하여야 한다.
- ⑦ 기타 복합기 보안과 관련한 사항은 국가정보원장이 배포한 「정보시스템 저장매체 불용처리지침」을 준수하여야 한다.

제78조(재난 방지대책) ① 각 기관의 장은 인위적 또는 자연적인 원인으로 인한 정보통신망의 장애 발생에 대비하여 정보시스템의 이중화, 백업관리 및 복구 등 종합적인 재난 방지대책을 수립·시행하여야 한다.

② 각 기관의 장은 재난 방지대책을 정기적으로 시험·검토하고 재난으로 인해 업무에 지장이 초래될 가능성에 대한 영향평가를 실시하여야 한다.

③ 각 기관의 장은 정보통신망의 장애 발생에 대비하여 정보시스템 백업시설을 확보하고 정기적으로 백업을 실시하여야 한다.

④ 각 기관의 장은 제3항에 따른 백업시설을 구축·운영하고자 할 경우 정보통신실·통합데이터센터와 물리적으로 일정거리 이상 떨어진 안전한 장소에 설치하여야 하며 전력공급원 이중화 등 정보시스템의 가용성을 최대화 할 수 있도록 하여야 한다.

제2절 정보보안 측정, 훈련 및 진단

제79조(대도청 측정) ① 각 기관의 장은 다음 각 호의 어느 하나에 해당하는 시설·장소에 대하여 각종 수단에 의한 도청으로부터 정보유출을 방지하기 위한 정책 또는 계획 수립 등 관리적 보안대책, 도청을 예방 또는 탐지·발견할

수 있는 물리적·기술적 보안대책을 수립·시행하여야 한다.

1. 기관 청사(신축, 이전 또는 증축, 개축, 대규모 수선 등)
2. 기관장실, 회의실 등 중요업무 장소
3. 중요회의·회담·협상·행사 장소
4. 기타 대도청 측정이 필요하다고 판단되는 시설·장소·장비

② 각 기관의 장은 제1항에 따른 시설·장소에 대하여 자체 또는 「통신비밀보호법」 제10조의3에 따른 불법감청설비탐지업자 활용 등을 통해 대도청 측정을 실시하여야 한다. 다만, 다음 각 호에 해당하는 시설·장소에 대하여는 국가정보원장에게 대도청 측정을 요청할 수 있다.

1. 국가기관의 장 또는 상급기관의 장이 관리하는 시설·장소
2. 하급기관의 장이 관리하는 시설·장소 중에서 관계 상급기관의 장이 국가안보 및 국익 보호를 위하여 필요하다고 판단하는 시설·장소

③ 제2항에 따라 자체 또는 불법감청설비탐지업자 등을 활용하여 측정을 실시한 기관의 장은 측정결과 취약요인이 발견된 경우 정보보안담당관에게 통보하여야 한다. 정보보안담당관은 국가정보원장에게 통보하여야 하고 기술 지원 및 추가 측정을 요청할 수 있다.

④ 제2항에 따라 국가정보원장이 측정을 실시한 결과 취약요인이 발견된 경우 해당 기관의 장은 개선대책을 수립·시행하여야 한다.

⑤ 각 기관의 장은 대도청 측정 결과를 「공공기관의 정보공개에 관한 법률」 제9조제1항에 따른 비공개 대상 정보로 지정·관리하여야 한다.

⑥ 기타 대도청 측정과 관련한 사항은 국가정보원장이 배포한 「도청 탐지·방어활동 가이드라인」을 준수하여야 한다.

제80조(사이버공격 대응훈련) 정보보안담당관은 각 기관에 대하여 「사이버안보 업무규정」 제11조에 따른 대응훈련 및 시정조치가 원활히 이루어질 수 있도록 지도·감독하여야 한다.

제81조(정보통신망 보안진단) 정보보안담당관은 「사이버안보 업무규정」 제12조제1항에 따른 진단·점검 또는 그 밖의 법규에 따라 정보통신망 보안진단

· 점검을 실시할 경우, 국가정보원장이 배포하는 다음 각 호의 가이드라인 등을 참고하여야 하며, 이에 필요한 관련예산 확보 등을 위하여 노력하여야 한다.

1. 사이버보안 강화를 위한 길라잡이(정보통신시스템 보안진단 및 대응방법)
2. 홈페이지·네트워크·시스템·DBMS 취약점 점검매뉴얼
3. 정보보안점검 체크리스트

제82조(정보보안 관리실태 평가) ① 정보보안담당관은 「사이버안보 업무규정」 제13조, 「전자정부법」 제56조 및 같은 법 시행령 제69조·제70조, 「공공기록물 관리에 관한 법률 시행령」 제5조 등에 따라 국가정보원장이 실시하는 정보보안 관리실태 평가를 받아야 한다.

② 정보보안담당관은 제1항과 관련하여 국가정보원장이 배포한 정보보안 관리실태 평가지표에 따라 자체 평가를 실시하여야 한다.

③ 정보보안담당관은 평가 결과에 따른 미비점을 개선·보완하여 정보보안 수준을 제고하여야 한다.

제 6 장 정보 협력

제83조(기관간 정보공유 협력) 각 기관의 장은 사이버공격의 예방 및 신속한 대응을 위하여 다음 각 호에 해당하는 정보를 기관 간 상호 공유하도록 노력하여야 한다.

1. 사이버공격의 방법 및 대응조치에 관한 정보
2. 사이버공격에 사용된 악성프로그램 및 이와 관련된 정보
3. 정보통신망, 정보통신기기, 정보보호시스템 및 소프트웨어의 보안취약점에 관한 정보
4. 그 밖에 사이버공격 예방 및 대응에 필요한 정보

제84조(정보공유시스템 이용) ① 정보보안담당관은 사이버안보 정보의 배포와 각급기관·단체간 사이버위협정보의 체계적·효율적 공유를 위하여 국가사이버위협 정보공유시스템(「사이버안보 업무규정」 제6조에 따른 정보공유시스템을 포함한다. 이하 "정보공유시스템"이라 한다)을 이용할 수 있다.

② 정보보안담당관은 정보공유시스템에 사이버위협 관련 정보 등을 등록하거나 등록된 정보를 업무에 활용할 수 있으며 다음 각 호에 해당하는 사항을 준수하여야 한다.

1. 정보공유시스템 전용(專用) 단말기 운용
2. 정보공유시스템 접근·활용 및 단말기 운용 등을 위한 관리자 지정·운영
3. 정보시스템 개별 이용자 등록·삭제 등 접근권한 관리
4. 정보공유시스템 전용(專用) 단말기 내 정보공유시스템 이용과 무관한 소프트웨어 설치 및 비인가 휴대용 저장매체 연결 사용 금지
5. 정보공유 활성화를 위하여 월 1회 이상 정보공유시스템 접속·활용
6. 기타 국가정보원장이 제시하는 보안대책

제85조(정보공유시스템의 정보 관리) ① 정보보안담당관은 정보공유시스템에 등록된 정보를 「공공기관의 정보공개에 관한 법률」 제9조제1항에 따른 비공개 대상 정보 및 「국가정보자료관리규정」 제2조제1호에 따른 국가정보자료로서 취급·관리함을 원칙으로 한다.

② 정보보안담당관은 정보공유시스템에 사이버위협 정보를 등록할 경우 보안성·민감성 등을 고려하여 열람권한 및 보안등급을 부여할 수 있다.

부 칙 <1999.11. 4>

이 지침은 발령한 날부터 시행한다.

부 칙 <2004.11. 5>

이 지침은 발령한 날부터 시행한다.

부 칙<2009. 8.28>

이 행정지침은 2009년 9월 1일부터 시행한다.

부 칙<2009. 8.28.>

이 훈령은 2009년 9월 1일부터 시행한다.

부 칙<2009.12.14.>

이 훈령은 발령한 날부터 시행한다.

부 칙<2010. 3.16.>

이 훈령은 발령한 날부터 시행한다.

부 칙<2011. 5.16.>

이 훈령은 발령한 날부터 시행한다.

부 칙<2015. 8.20.>

이 훈령은 발령한 날부터 시행한다.

부 칙<2019. 11. 1.>

이 훈령은 발령한 날부터 시행한다.

부 칙<2020. 6. 1.>

이 훈령은 발령한 날부터 시행한다.

부 칙<2021. 8. 25.>

이 훈령은 발령한 날부터 시행한다.

부 칙<2022. 1.19.>

이 훈령은 발령한 날부터 시행한다.

부칙(국가유산체제 전환 및 정부조직개편에 따른 「(문화재청) 국가보호종 보존협의회

구성 및 운영에 관한 규정」 등의 정비에 관한 훈령) <제2호, 2024. 5. 17.>

이 훈령은 2024년 5월 17일부터 시행한다.

[별표 1]

‘안전성 검증필 제품 목록’ 등재 기본요건

X : 해당사항 없음

제품 유형	아래 해당되는 항목 중에서 어느 하나 필요				검증필 암호모듈
	CC인증 ¹⁾	성능평가 ²⁾	보안기능 확인서 ³⁾	보안적합성 검증 ⁴⁾	
스마트카드		X	X	○	X
침입차단시스템		X		X	X
침입방지시스템		X		X	X
통합보안관리제품		X		X	X
웹 방화벽		X		X	X
운영체제(서버) 접근통제제품		X		X	X
DB접근통제제품		X		X	X
네트워크접근통제제품	국가용 보안요구사항	X		X	X
인터넷전화 보안제품		X		X	X
무선침입방지시스템	또는	X		X	X
무선랜 인증제품		X		X	X
가상사설망제품	국가용 보호프로파일	X		X	탑재 필요
디지털복합기	(PP) 준수	X		X	X
스마트폰 보안관리제품		X	국가용·일반 보안요구사항 준수	X	X
스팸메일차단시스템		X		X	X
패치관리시스템		X		X	X
망간자료전송제품 ⁵⁾		X		X	X
DDoS 대응장비				X	X
안티바이러스제품				X	X
소스코드 보안약점 분석도구				X	X
네트워크 자료유출방지제품	X	X		X	X
호스트 자료유출방지제품	X	X		X	탑재 필요
S/W기반 보안USB제품	X	X		X	탑재 필요
가상화관리제품	X	X		X	X
네트워크 장비 ⁶⁾	X	X		X	X
저장자료 완전삭제제품	X	X	X	○	X

1) 「지능정보화 기본법」 제58조제1항 및 같은 법 시행령 제51조에 따라 과학기술정보통신부장관이 고

시한 「정보보호시스템 평가·인증 지침」에 따른 인증(국내용 CC 또는 국제용 CC). 다만, 인증범위 (TOE)에 각급기관이 사용할 보안기능이 포함되어 있어야 함

2) 「정보보호산업의 진흥에 관한 법률」 제17조에 따른 성능평가

3) 본 지침 제19조의2에 따라 보안기능 시험기관이 발급하는 확인 증서

4) 본 지침 제2장제5절에 따른 보안적합성 검증

5) 망간자료전송제품은 2022.1월부터 'CC인증'에서 '보안기능 확인서'로 도입요건이 변경됨

6) 네트워크 장비는 L3 이상 스위치 및 라우터 등을 의미

※ 다수 H/W에 탑재, 배포되는 제품이 "CC인증" 또는 "보안기능 확인서"를 발급받은 경우, 해당 인증서 또는 보안기능 확인서에 H/W 모델명 기재 필요

※ 「소프트웨어 진흥법」 제20조에 따른 품질인증(GS인증)을 받은 제품 중에서 국가용 보안요구사항을 준수하는 제품의 목록 등재에 관하여는 국가정보원 홈페이지 참고

※ 同 지침 시행일로부터 차후에 지침이 개정되는 날까지의 기간 중에, 국가정보원 홈페이지에 同 별표의 변경이 공지될 수 있으며, 이 경우 홈페이지에 공지된 별표 내용을 同 지침상의 별표로 봄

[별표 2]

‘암호가 주기능인 제품’ 도입요건

제품 유형	도입 요건	비 고
메일 암호화제품	검증필 암호모듈 탑재	
구간 암호화제품		
하드웨어 보안토큰		
디스크·파일 암호화제품		
기타 암호화제품		
SSO제품	검증필 암호모듈 탑재 및 CC인증(국가용 보호프로파일 준수)	
DB 암호화제품		
문서 암호화제품(DRM 등)		

※ 최신 도입요건은 국가정보원 홈페이지(암호모듈 검증) 참조

[별표 3]

보안적합성 검증 신청시 제출물

1. 최초검증 신청시 제출물

제출물	정보보호시스템		작성 주체
	상용 제품	자체(용역) 개발	
[서식 제1호]에 따른 보안적합성 검증 신청서	○	○	신청기관
[서식 제3호]에 따른 정보통신제품 도입확인서(현황)	○	○	
기술제안요청서 사본	○	○	
보안기능 점검표	○	○	
운용점검사항	○	○	
CC인증서 사본	○ (인증서 보유시)		업체
보안기능 운용 설명서	○	○	
기본 및 상세 설계서		○	
개발완료 보고서		○	

2. 재검증 신청시 제출물

제출물	정보보호시스템		작성 주체
	상용 제품	자체(용역) 개발	
[서식 제1호]에 따른 보안적합성 검증 신청서	○	○	신청기관
[서식 제3호]에 따른 정보통신제품 도입확인서(현황)	○	○	
보안기능 점검표	○	○	
운용점검사항	○	○	
변경내용 분석서	○	○	업체

[별표 4]

저장매체 · 자료별 삭제 방법

저장 자료 저장 매체	공개 자료	비공개 자료	대외비 자료	비밀 자료
자기테이프 플로피디스크	자체 판단	물리적 파괴	물리적 파괴	물리적 파괴
광디스크 (CD · DVD 등)	자체 판단	물리적 파괴	물리적 파괴	물리적 파괴
반도체메모리 (SSD · USB 등)	포맷 또는 삭제	완전삭제 제품	물리적 파괴	물리적 파괴
하드디스크	포맷 또는 삭제	디가우징 또는 완전삭제 제품	물리적 파괴	물리적 파괴

* 반도체메모리의 경우 최초 사용시부터 디스크 암호화(BitLocker 등)를 사용하고
암호키는 「국가 정보보안 기본지침」 제76조에 따라 설정하여야 완전삭제 가능

[별표 5]

정보보안 위규자 처리기준

구분	정보보안 위규사항		처리기준				
			중징계	경징계	경고	주의	별당직
보안시스템 분실	분실후 미회수	미신고	○				
		신고	○				
	분실후 회수	미신고	○				
		신고		○			
보안시스템 관리 위반	보안시스템을 고의적으로 유기		○				
	보안시스템을 비인가자가 관리			○			
	암호자재·암호장비 사용법 미준수				○		
	불순한 의도로 보안자재를 불법 복제·복사·촬영하 거나 암호자재를 외부 정보통신망에 게시		○				
	교육 및 전파 목적으로 보안자재를 불법 복제·복 사·촬영하여 전산망에 게시		○				
	보안자재를 과실에 의해 전산망에 게시			○			
정보시스템 관리 위반	국가정보시스템 및 전산망 대상 고의적 해킹 및 악성코드 유포		○				
	PC·서버 등 정보시스템 해킹 으로 피해 발생	비밀 유출	○				
		대외비 유출		○			
		업무자료 유출			○		
	비인가 정보시스템(서버, PC, 노트북, 태블릿 등) 반입·사용			○	⊖		
	해킹사고 인지 후 미신고			○	⊖		
	해킹 및 악성코드에 감염된 정보시스템 훼손 등 정당한 침해사고 조사행위 방해			⊖	○		
	해킹·악성코드 등 침해사고 예방대책 미강구				○		
	해커가 인지한 이메일주소 변경사용 권고 후에도 지속 사용				○		
	과실에 의해 악성코드가 감염되었으나 피해 심각 (중요자료 대량 유출, 2개망 이상에 전파 등)			○			
	과실에 의해 악성코드를 감염시켰을 때				○	⊖	
	인터넷망 (외부망)	비밀을 임의저장·게시·공유·전송	○				
		대외비를 임의저장·게시·공유·전송		○			
		업무자료를 임의저장·게시·공유·전송			○		
		외부전산망을 무단 설치·운용	○				
	업무망 (내부망)	비밀을 임의저장·게시·공유·전송		○			
		대외비를 임의저장·게시·공유·전송			○		
		외부망과 임의 연동하거나 불법접속		○			
	국가정보시스템 손괴 및 부정사용, 비인가 프로그 램 사용 등 고의적으로 정보시스템 장애 발생		○				
	공직기강 및 품위 훼손을 야기하는 등 업무와 무 관한 자료 또는 소프트웨어 게시				○		
	기관 정보통신기기 임의 반출			○			

구분	정보보안 위규사항			처리기준				
				중징계	경징계	경고	주의	벌당직
정보시스템 관리 위반	정보시스템 불용처리시 저장매체 미삭제·미소거 처리					○		
	정보시스템을 무력화·우회·편법 사용할 목적으로 관련 기법을 전파 또는 공유				⊖	○		
	필수 보안프로그램(백신, 매체제어 등) 미설치 및 우회하여 정보시스템 사용					○		
	외부 업체 직원의 전산망 임의 접속, 자료 열람, 악성코드 유포 등을 초래한 업무담당자				⊖	○		
	비인가 서버 구축 및 서비스(홈페이지, 게시판, FTP, 게임 등) 운용				○			
	비인가 소프트웨어 설치 또는 사용					○		
	상용 이메일, 상용 메신저 무단 사용							○
	보안대책 검토 및 보안측정 등 보안절차를 준수 하지 않거나 검토·측정결과 조치 미흡					○	⊖	
	사전 승인 및 보안성검토·적합성 검증 없이 정보 시스템 개발·도입					○	⊖	
	노트북·PC 등 단말기 内 비인가된 무선통신기능 미제거					○	⊖	
	비밀번호 누설·도용 및 타인 계정 무단 사용				○			
	비밀번호 운용규정 미준수					○	⊖	
저장매체 무단반출	비밀용			○				
	대외비용				○			
	일반업무용					○		
저장매체 분실	비밀/대외비용	분실후 미회수	미신고	○				
			신고		○			
		분실후 회수	미신고	○				
			신고		○			
	일반용	분실후 미회수	미신고		○			
			신고			○		
		분실후 회수	미신고			○		
			신고					
저장매체 파기	비밀용 저장매체 무단 파기			○				
비인가 저장매체 반입	비밀 저장			○				
	대외비 저장				○			
	단순반입					○		
상시 정보보안 활동 위반	정보보안 교육 미참여						⊖	○
	해킹메일 훈련		열람 후 미신고					○
기타	경고 2회 이상 처벌 받은 인원의 재위반				○			

[서식 제1호]

보안적합성 검증 신청서

신청 기관	기관명		담당자	
	부서명		전화번호	
	사업명		이메일 ※ 상용메일 불가	
	도입 목적			
	보안성 검토명		계약 날짜	
			도입 날짜	
검증결과 반영	취약점 등의 개선요청 이행 (☐ 반영·개선 ☐ 반영불가)			
신청 제품	제품명		S/W(펌웨어) 버전	
	※ 신청 제품이 2種 이상인 경우, 별도 신청			
	제품 유형		도입 수량	대
	사전 인증 대상 여부	☐ CC인증 대상 ☐ 검증필 암호모듈 탑재 ☐ 해당 없음 ※ CC인증·검증필 암호모듈 탑재 필수 제품은 국정원 홈페이지 참조		
	해시값 (SHA-512)	※ 해시값은 국정원 홈페이지에 게시된 S/W 사용		
	CC 인증기관		CC 인증등급	
	CC 인증번호		CC 만료일	
	암호모듈명		암호검증 번호	CM-
업체	업체명		대표자	
	주소			
	담당자명		전화번호	
	휴대폰번호		이메일	

※ △서식이 변경될 수 있으므로 국가정보원 홈페이지(튼튼한 안보→사이버안보→보안적합성 검증 →검증공지 사항)에 게시된 양식을 참고 △'검증결과 반영'을 포함하여 기재 양식중 해당사항은 빠짐없이 기재

[서식 제2호]

정보통신제품 도입 확인서(현황)

기관명		관계 중앙행정기관	
담당자		담당자 전화번호	
사업명			
보안성	보안성 검토받은 문서 제목 및 번호 표시 예) 000 보안성 검토결과(000-000, 2019.1.1)		

[illegible]

※ △서식이 변경될 수 있으므로 국가정보원 홈페이지(든든한 안보→사이버안보→보안적합성 검증→검증 공지 사항)에 게시된 양식을 참고하되, 반드시 엑셀(xlsx)양식을 준수 △해시값은 국가정보원 홈페이지에 등재된 S/W 활용

[서식 제3호]

정보시스템 관리대장

[illegible]

[서식 제4호]

정보시스템(PC, 서버 포함) 취급자 관리대장

[illegible]

[서식 제5호]

통제구역 출입자 관리대장

[년도]

[illegible]

[서식 제6호]

휴대용 저장매체 관리대장(□일반용 □비밀용)

<관리책임자 : >

[illegible]

[서식 제7호]

휴대용 저장매체 점검대장

<관리책임자 : >

[illegible]

[서식 제8호]

휴대용 저장매체(전산장비 포함) 반출·입 대장

<관리책임자 : >

장비명	관리번호 (시리얼번호)	사용자	구분 (반출/반입)	사유	반출·입 일시	관리책임자 확인

[서식 제9호]

휴대용 저장매체 불용처리 확인서

아래와 같이 저장매체(종 점) 불용처리 및 저장매체(종 점) 재사용에
대해 확인을 요청함

연번	관리번호	매체형태	사유	불용처리	재사용

확인일자 : 년 월 일

요 청 자 : 소속·직책 O급 성명 : (서명 또는 인)

확 인 자 : 정보보안담당관 O급 성명 : (서명 또는 인)